

SPCI108

POSTGRADUATE COURSE

M.Sc. - Cyber Forensics & Information Security

FIRST YEAR

SECOND SEMESTER

CORE PAPER - VII

IT AND TELECOM FRAUDS & COUNTERMEASURES



**INSTITUTE OF DISTANCE EDUCATION
UNIVERSITY OF MADRAS**

WELCOME

Warm Greetings.

It is with a great pleasure to welcome you as a student of Institute of Distance Education, University of Madras. It is a proud moment for the Institute of distance education as you are entering into a cafeteria system of learning process as envisaged by the University Grants Commission. Yes, we have framed and introduced Choice Based Credit System(CBCS) in Semester pattern from the academic year 2018-19. You are free to choose courses, as per the Regulations, to attain the target of total number of credits set for each course and also each degree programme. What is a credit? To earn one credit in a semester you have to spend 30 hours of learning process. Each course has a weightage in terms of credits. Credits are assigned by taking into account of its level of subject content. For instance, if one particular course or paper has 4 credits then you have to spend 120 hours of self-learning in a semester. You are advised to plan the strategy to devote hours of self-study in the learning process. You will be assessed periodically by means of tests, assignments and quizzes either in class room or laboratory or field work. In the case of PG (UG), Continuous Internal Assessment for 20(25) percentage and End Semester University Examination for 80 (75) percentage of the maximum score for a course / paper. The theory paper in the end semester examination will bring out your various skills: namely basic knowledge about subject, memory recall, application, analysis, comprehension and descriptive writing. We will always have in mind while training you in conducting experiments, analyzing the performance during laboratory work, and observing the outcomes to bring out the truth from the experiment, and we measure these skills in the end semester examination. You will be guided by well experienced faculty.

I invite you to join the CBCS in Semester System to gain rich knowledge leisurely at your will and wish. Choose the right courses at right times so as to erect your flag of success. We always encourage and enlighten to excel and empower. We are the cross bearers to make you a torch bearer to have a bright future.

With best wishes from mind and heart,

DIRECTOR i/c

M.Sc. Cyber Forensics & Information Security
FIRST YEAR - SECOND SEMESTER

CORE PAPER - VII
IT AND TELECOM FRAUDS
& COUNTERMEASURES

**COURSE COMPILED, WRITTEN &
EDITED BY**

Dr. N. Kala
Director i/c
Cyber Forensics and Information Security,
University of Madras
Chennai

M.Sc. DEGREE COURSE

FIRST YEAR

SECOND SEMESTER

Core Paper - VII

IT AND TELECOM FRAUDS & COUNTERMEASURES

SYLLABUS

Unit 1 : Frauds in IT - IT Frauds (Theft of Proprietary Information, Insider abuse of internet access, system penetration, unauthorised access to information, laptop/mobile theft, financial fraud, misuse of public web application, virus, abuse of wireless network) – Countermeasures.

Unit 2: Introduction to Telecom Frauds - What is 'Telecommunication Fraud'? - Telecommunication Technologies referred (GSM, CDMA, GPRS, PBX, NGN Networks, Analog Networks) - About Fraudsters - Benefits to Fraudsters - Using a service without - Call selling to others - Root Causes of Fraud - Mitigation and Demographics - Penetration of new technology - Staff Dissatisfaction – Illustrative cases

Unit 3: Classification of Telecommunication Fraud - Frauds in different segments of Telco operations (such as Customer Care, Operational Support Systems, Network Management Systems) Organizational or Non-Technical Fraud (involving Administration services, processes) - Human Fraud - Insider Fraud - Call-sell Fraud - Facilitation Fraud - Creeping Fraud - Chaining Fraud - Calling-Card Fraud - Phantom Account - Partnership Fraud - Process Fraud – Ghosting - Abuse of test or emergency lines or accounts - Unauthorized Feature/Service Activation – Accounting - Dealer or Reseller Fraud - Subscription Fraud - Roaming Subscription Fraud - Premium-Rate Services Fraud- Illustrative Cases - Technical Fraud (involving Network Systems, Billing Systems) – Cloning – Tumbling - Voice-mail Hacking - PBX Hacking - SIM Stuffing- Clip-on Fraud - Line Tapping - War Dialing - Handset Fraud

Unit 4: Frauds in Fixed Network & Mobile Network: Fixed network Fraud - The development of Fixed Networks - Common types of Frauds affecting Fixed line telcos - Subscription Fraud - Physical attacks on networks - Premium rate fraud - PBX/DISA fraud - Threat of SS7 attacks - Methods of mitigating the risks these practices present Mobile network Fraud - The security of mobile networks - Frauds in wireless domain - Before Pre-Call Validation - After Pre-Call Validation - Fraud Detection Systems - Subscription Fraud - The best ways to reduce the risk of mobile network fraud

Unit 5: Common Telecommunication Frauds - Clip-on and Boxing Fraud - EPABX Hacking - Unauthorized disclosure of information - Unauthorized amendment of data - Denial of Service attack - Toll Fraud (call theft) - Mailbox abuse - Fax abuse - Vulnerabilities and their Impact – Controls - Security Policy - Managing the Risks - Awareness Training - Controlling Physical Access - Controlling Logical Access - Illustrative Cases - Calling-Card Theft - Call Forwarding Scams – Cloning - Cloning in GSM Networks - Tumbling or Magic Phones - Dealer or Reseller Fraud - Pre-paid Fraud - Social Engineering and Friendly Fraud - Insider Fraud - Identity Theft – Delinquency - Local Subscription Fraud - Roaming Subscription Fraud - Content and Value Added Services (VAS) Fraud - Common Fraud Techniques used today **Frauds in 3G Networks** - Introduction to 3G Technology and Services - The 3G Business Model - Telecom Frauds in a 3G environment - Subscription Fraud - Credit-card Fraud on M-commerce - Micro-payment Fraud - Premium rate Services (PRS) Frauds - Copyright Infringement and content resale frauds ('piracy') - IP Security issues in 3G – Hacking - DOS Attacks - Virus, Worms and Trojans - Data Interception - Database attacks – Spam - How network security needs to change with the move to 3G - Security and Law enforcement issues in 3G – Fraud Management Perspective - – **A Strategic Perspective** - Telecom Laws – Domestic and International - Fraud Management System - Architecture of an FMS solution

M.Sc. DEGREE COURSE
FIRST YEAR
SECOND SEMESTER
Core Paper - VII
IT AND TELECOM FRAUDS & COUNTERMEASURES
SCHEME OF LESSONS

Sl.No.	Title	Page
1	Frauds in IT, Software Development and Management	1
2	Introduction to Telecom Frauds	17
3	Classification of Telecommunication Fraud - Part - II	24
4	Classification of Telecommunication Fraud - Part - III	43
5	Fixed Network Fraud	49
6	Mobile Network Fraud	56
7	Common Telecommunication Frauds	59
8	Frauds in 3G Networks	73
9	Fraud Management - A Strategic Perspective fraud management system	83
10	Frauds in 4G/LTE Networks	93

Lesson - 1

Frauds in it, Software Development and Management

Learning Objectives

After reading this unit, you will be able to

- Understand the types of IT Frauds
- Know the fraud risk assessment prevention detection and investigation

Structure

- 1.1 IT Frauds (Computer Frauds)**
- 1.2 Roles of IT Auditor in Fraud Control**
- 1.3 IT Processes**
- 1.4 Types of Fraud**
- 1.5 Fraud Risk Assessment**
- 1.6 Fraud Prevention**
- 1.7 Fraud Detection**
- 1.8 Fraud Investigation**
- 1.9 Conclusion**

1.1 IT Frauds (Computer Frauds)

Computer Fraud is the use of Information Technology to commit fraud. This includes covering all components of IT starting from the end user computing devices like laptops, desktops, mobile equipment's to networking devices like routers, switches, wireless devices to software's and applications etc.

The IT sector has grown immensely and has achieved significant milestones in terms of value creation. In this scenario, the threat of frauds has grown faster than anticipated. New risks have emerged and this has fostered opportunities and incentives for fraud resulting in a steep increase in the value and quantum of frauds in IT sector.

Fraud is often difficult to detect and even harder to prove in a court of law. This paper provides insight into common practices applicable to practicing professionals who are auditing for fraud in an information technology (IT) environment. Some examples include

IP fraud: An employee of a software development company sold the source code of the new software developed by the company to its competitors.

Data theft: An employee of an organization sold a CD, suspected to contain confidential data pertaining to the customers of a bank.

Forex fraud: An employee of a leading software company without proper authorization hedged the foreign exchange receivable by the company outside the normal course of the company's hedging process, which resulted in a loss of US\$30 million to the company.

Employee embezzlement fraud: An employee of a large software services company was able to steal the password of the bank account of the company and embezzle an amount in excess of US\$5 million.

Procurement fraud: Employees of a technology company were sacked for allegedly showing preference to certain vendors/service providers and demanding favors from certain other vendors in lieu of the timely processing of their invoices/bills and the renewal of contracts.

Recruitment fraud: The entire recruitment team of a large IT company was sacked for allegedly accepting bribes from prospective employees and recruitment consultants.

Payroll fraud: An employee of a company drew salary even after six months of leaving the company.

Refund fraud: Employees working in an organization misused their authority and created 30 dummy customer e-mail IDs and embezzled more than US\$1M, which was supposed to be paid as refund for dissatisfied customers.

Misappropriation of funds: Few employees opened several dummy accounts to transfer the customer funds to these fictitious accounts.

The term "occupational fraud" is defined as "the use of one's occupation for personal enrichment through the deliberate misuse or misapplication of the employing organization's resources or assets." The study used as the basis for this definition was compiled from data

associated with 1,134 occupational fraud investigation cases and the selected key findings of this report concluded that:

- US organizations suffered an estimated 5 percent loss of annual revenues to fraud (estimated at approximately US \$652 billion)
- The median financial loss due to occupational fraud was US \$159,000
- Less than 8 percent of the perpetrators had convictions prior to committing their frauds
- The extent of fraud losses was strongly related to the position of the perpetrator

1.2 Roles of IT Auditor in Fraud Control

Whether or not an auditor is auditing for fraud, all auditors are expected to assume responsibility for detecting fraud and assessing antifraud programs. The Statement on Auditing Standards (SAS) 99 of the American Institute of Certified Public Accountants (AICPA) emphasizes auditors exercising their professional skepticism to identify risks that may result in a material misstatement due to fraud. The US Public Company Accounting Oversight Board (PCAOB) also requires auditors to evaluate fraud-related activities as a component of an internal audit function.

With rapid advancements in information communications and technologies (ICT) and an increasingly mobile accessible environment (i.e., wireless networking), it is no surprise that companies are increasingly reliant on IT equipment and applications for the delivery of company operations. IT audit provides a vital role in the prevention, detection and investigation of fraud.

To make a valuable contribution toward fraud control, requirements need to be elaborated on and understood by the IT auditor with respect to the various IT processes and types of fraud, each of which contributes to the development of fraud risk assessment.

1.3 IT Processes

Control Objectives for Information and related Technology (COBIT)⁵ provides excellent coverage of IT processes. An IT process, according to COBIT, can be classified into one of five specific domains:

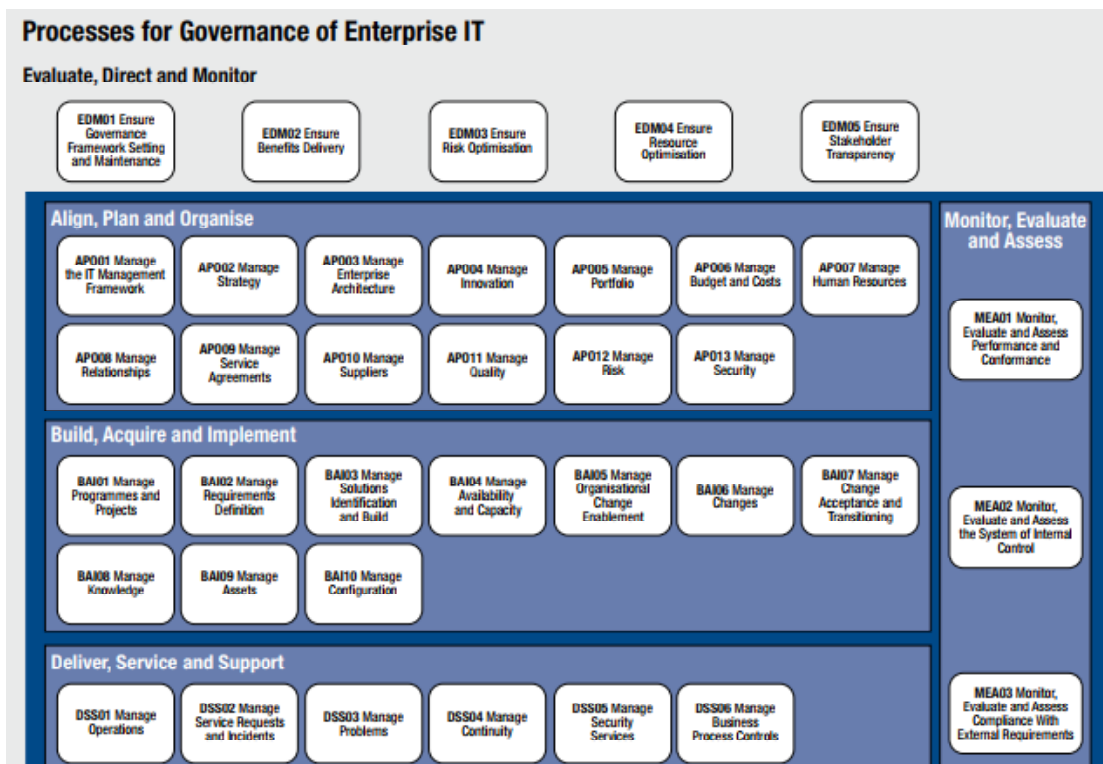
- Evaluate, Direct and Monitor (EDM)
- Align, Plan and Organize (APO)

- Build, Acquire and Implement (BAI)
- Deliver, Service and Support (DS)
- Monitor, Evaluate and Assess (MEA)

A total of 37 IT processes are listed within these five domains, as shown in **figure 1**.

Figure 1.1 : Cobit Reference Model

COBIT 5 Process Reference Model



For each process the following information is included, in line with the process model explained in the previous chapter:

- Process identification
 - o Process label - The domain prefix (EDM, APO, BAI, DSS, and MEA) and the process number

- o Process name - A short description, indicating the main subject of the process
- o Area of the process - Governance or management
- o Domain name
- Process description - An overview of what the process does and a high-level overview of how the process accomplishes its purpose
- Process purpose statement - A description of the overall purpose of the process
- Process goals and metrics - A set of process goals and a limited number of example metrics
- RACI chart - A suggested assignment of level of responsibility for process practices to different roles and structures.

The enterprise roles listed are shaded darker than the IT roles. The different levels of involvement are:

Responsible - Who is getting the task done? This refers to the roles taking the main operational stake in fulfilling the activity listed and creating the intended outcome

Accountable - Who accounts for the success of the task? This assigns the overall accountability for getting the task done (Where does the buck stop?). To enable empowerment of the enterprise, accountability is broken down as far as possible. Accountability does not indicate that the role has no operational activities; it is very likely that the role gets involved in the task. As a principle, accountability cannot be shared.

Consulted - Who is providing input? These are key roles that provide input. Note that it is up to the accountable and responsible role(s) to obtain information from other units or external partners, too. However, inputs from the roles listed are to be considered and, if required, appropriate action has to be taken for escalation, including the information of the process owner and/or the steering committee.

Informed - Who is receiving information? These are roles who are informed of the achievements and/or deliverables of the task. The role in 'accountable', of course, should always receive appropriate information to oversee the task, as does the responsible roles for their area of interest.

- Detailed description of the process practices - For each practice:
 - o Practice title and description
 - o Practice inputs and outputs, with indication of origin and destination
 - o Process activities, further detailing the practices
- Related guidance—References to other standards and direction to additional guidance

Inputs and Outputs

The detailed process descriptions contain inputs and outputs, at the level of the governance and management practices

In general, each output is sent to one or a limited number of destinations, typically another COBIT process practice. That output then becomes an input to its destination. However, there are a number of outputs that have many destinations, e.g., all COBIT processes, or all processes within a domain.

Whether or not a fraud is likely to occur in each of the identified IT processes is debatable. To better understand if a fraud is likely to occur, the fraud triangle hypothesis, developed by criminologist Dr. Donald R. Cressey, should be considered by all auditors. According to Cressey, three factors, are associated with any person who commits fraud, namely opportunity, perceived pressure and Rationalization.

Since there is a human association in any IT process, regardless of the IT system's degree of automation, the possibility of a fraud should always be considered.

1.4 Types of Fraud

Typically, occupational frauds fall into one of three major categories:

1. **Asset misappropriation** – Any scheme that involves the theft or misuse of an organization's assets, e.g., use of software and software licenses purchased by the company for personal use or financial gain
2. **Corruption**- Any scheme in which a person uses his/her influence in a business transaction to obtain an unauthorized benefit contrary to that person's duty to his/her employer, e.g., awarding outsourcing IT equipment maintenance services to the vendor that provides cash and/or gifts

- 3. Fraudulent statement** -The falsification of an organization's financial statement to make it appear more or less profitable, e.g., spending to adjust the average revenue per user (ARPU) figure of the telecommunications operator.

Each of these categories can be further broken down into different fraud schemes. The knowledge of different types of fraud and awareness of common fraud schemes across industries can greatly facilitate the appropriateness and accuracy of fraud risk assessments.

The key reasons why such frauds take place:

The absence of policies and procedures aimed at preventing and deterring employees/ vendors from committing fraud contributes immensely to rising fraud cases. In some organizations while the policies exist, the same may not have been communicated adequately and appropriately.

One of the key reason is the high growth rate in the information technology sector, coupled with a higher attrition rate. This combination puts extreme pressure on processes/controls and could lead to non-adherence to established processes and controls, which ultimately results in financial/ efficiency/reputation loss.

There is an absence of dedicated efforts/ specialized skill sets to prevent/ detect fraud under pressure situations. The internal audit teams may not be equipped with the necessary skills/tools required to prevent and/or detect frauds by employees/others.

The misuse of the trust and responsibility obtained in an organization is another key cause for committing frauds. The pressure of expectations has been a determining factor for some of the employees in their attitude towards fraud.

1.5 Impact of Frauds

Frauds cause severe damage to the reputation of the company.

- In many cases, fraud instances have resulted in direct loss of business to the company.
- Frauds expose the company to civil or criminal liabilities.
- Legislative requirements or compliance procedures increase in the light of fraud cases.

Legislative requirements regarding fraud risk management:

- The issue of data protection is to a certain extent addressed by the introduction of the Information Technology (Amendment) Act, 2008. However, it does not cover the issues of data protection for data sent outside the territories of India.
- Legislations such as The Sarbanes Oxley Act, The Foreign Corrupt Practices Act & SAS 99 require the management of US/US-listed companies to set up strong internal controls for the prevention and detection of fraud.
- Similarly, Indian legislations such as Clause 49 of the Listing Agreement and the 'Standards on Auditing 240' has put the primary onus for the prevention and detection of fraud on the management and those charged with governance.
- In accordance with the "Corporate Governance Voluntary Guidelines 2009" released by the Ministry of Corporate Affairs: "Companies should ensure the institution of mechanism for employees to report concerns about the unethical behavior actual or suspected fraud, or violation of the company's code of conduct or ethics policy."

1.6 Fraud Risk Assessment

The fraud risk assessment begins with ranking the likelihood and significance of fraud activities associated with IT processes. PCAOB Auditing Standard (AS) No. 2 provides an example of the probability of a risk and its corresponding significance. This PCAOB standard specifies three risk levels:

- Remote
- More than remote
- Probable

The PCAOB standard also defines significance of a risk into three categories:

- Inconsequential
- More than inconsequential
- Material

Figure 1.2 illustrates the relationship between the significance of the probability of risk.

		Impact →				
		Negligible	Minor	Moderate	Significant	Severe
Likelihood ↑	Very Likely	Low Med	Medium	Med Hi	High	High
	Likely	Low	Low Med	Medium	Med Hi	High
	Possible	Low	Low Med	Medium	Med Hi	Med Hi
	Unlikely	Low	Low Med	Low Med	Medium	Med Hi
	Very Unlikely	Low	Low	Low Med	Medium	Medium

Figure 1.2: Relationship between the significance of probability and risk

Upon the completion of ranking fraud activities associated with IT processes, the fraud risk assessment process can map the IT processes with types of fraud and controls in place (if any), as shown in **figure 1.3**.

- **Directive controls:** Often called administrative controls, these are intended to advise employees of the behavior expected of them during their interfaces with or use the organization's information systems.
- **Preventive controls:** Included in preventive controls are physical, administrative, and technical measures intended to preclude actions violating policy or increasing risk to system resources.
- **Deterrent controls:** Deterrent controls involve the use of warnings of consequences to security violations.
- **Detective controls:** Detective controls involve the use of practices, processes, and tools that identify and possibly react to security violations.
- **Corrective controls:** Corrective controls also involve physical, administrative, and technical measures designed to react to detection of an incident in order to reduce or eliminate the opportunity for the unwanted event to recur.
- **Recovery controls:** Once an incident occurs that results in the compromise of integrity or availability, the implementation of recovery controls is necessary to restore the system or operation to a normal operating state.

Figure 1.3: Controls in Place

Fraud risk assessments allow organizations to easily visualize the areas for occurrence of fraud and prioritize their resources against these potential fraud areas. Since both the business and IT environments are changing rapidly, the fraud risk assessment should be carried out on a regular basis or whenever there is a major change in an IT process. Furthermore, in identifying an IT process for fraud risk assessment, an auditor may use history patterns of fraud within the company as a benchmark reference.

1.6 Fraud Prevention

Most customers and regulators understand the possibility of fraud instances. However, they consider the following mitigating factors:

- What preventive mechanism does an organization have in order to prevent such fraudulent acts?
- How quickly and how well can the organization respond when such instances of fraud actually happen?

In the best interest of the IT companies, they need to proactively undertake a self-assessment of their existing fraud prevention processes and controls. IT companies need to ensure that the existing processes and controls are robust and are operating effectively to prevent the occurrence or recurrence of such incidents.

“The recent cases of fraud have raised questions over the preparedness of organizations in preventing, detecting and handling frauds.

The term prevention is self-explanatory—to stop something from happening. Common sense tells us that it is more costly to make a change after the completion of product, project or IT application, than to have the right design in the beginning. Fraud prevention applies to activities auditors are already undertaking today. Auditors have an increasing influence on the early stages of development of a business product, process or IT application. Wherever controls are found to be inadequate to protect against fraud risks, or the risk level is rated as being “more than remote” or higher and simultaneously at a “more than inconsequential” level (or greater) in terms of financial value, appropriate measures should be designed, selected and integrated to prevent, detect and/or minimize the fraud in a timely manner (refer to figure 3). These measures can be built-in controls (BICs), integrated as part of particular processes to deter potential frauds, or early warning signals (EWSs) on occurrence of frauds. **Figure 5** provides samples of BICs and EWSs for consideration.

Fraud is expensive and disruptive, making prevention preferable to investigation and recovery. Preventing fraud before it happens is the ultimate goal of a successful prevention and awareness program

The likelihood of fraud can be reduced by implementing antifraud programs and controls. Besides the development of comprehensive policies and procedures, implementation of antifraud programs requires effective communication, implementation and compliance monitoring. This can be achieved in three steps as described below

- **Create an anti-fraud environment:**

Management should strive hard to create an environment where people believe that fraudulent acts will not be tolerated at all, i.e., a zero tolerance level should be established for fraud/ other dishonest acts. This can be achieved through the development and implementation of:

- **Fraud policy:**

The development and communication of a strict fraud policy is expected to set the standard for intolerance of fraudulent behavior. This policy should communicate that the company is committed and willing to take a proactive approach to prevent, detect and report fraud.

Further, it should clearly state the consequences of fraudulent acts when fraud is uncovered.

- **Code of business conduct/ethics policy:**

The code of conduct/ethics policy should be comprehensive and should describe acts that constitute unethical/non-acceptable behavior. Depending on the nature of operations, complexity and its size, an organization may devise a policy that is applicable to all the employees (and all operating units).

Additional specific policies may be devised for specific operating units/certain categories of the management/key employees.

- **Whistle blower policy/fraud hotlines:**

As multiple global surveys carried out by various organizations over the past several years have pointed out, fraud hotlines/tip offs are one of the most successful tools to detect fraud. An effective whistle blowing policy should be such that employees are able to report/

voice their suspicions of fraud occurrence without the fear of disciplinary action or retaliation against them

- **Fraud response plan**

The fraud response plan is a step-by-step process of the procedures that should be followed by management, should an incident of fraud occur. Too often, when an organization experiences an incident of fraud, the management is not aware of action to be taken, which exposes the organization to various vulnerabilities, including litigation.

- **Fraud awareness training sessions and workshops**

A crucial element in preventing fraud in organizations is providing fraud awareness training to the relevant staff.

Companies should devise and conduct fraud prevention and awareness workshops, which are focused on changing cultures and attitudes toward fraud by raising awareness. These workshops involve employees' sensitization to probable fraud types and the warning signs and effective response training to fraud events

2. Undertake comprehensive fraud risk assessment

Every organization has inherent and specific fraud risks that depend on factors such as industry, size, organization structure, internal controls environment, geographical location, etc. Organizations are increasingly considering fraud risk as a part of the companywide risk assessment programs to help them identify fraud risks and implement effective antifraud controls.

The key steps involved in this process are:

- Consideration of various types of fraud risks, viz., theft, employee fraud, fraudulent financial reporting, misappropriation of assets, etc.
- Consideration of various fraud schemes and scenarios unique to the industry/company
- Assessment of fraud risks at the overall company level, significant business unit level and significant account levels
- Mapping of existing controls and evaluation of effectiveness of controls
- Designing the implementation framework and monitoring mechanisms

- Conducting vulnerability reviews of various processes to the fraud risk and identifying areas where the anti-fraud controls are not working effectively

3. Implement adequate oversight/monitoring

- Adequate monitoring procedures should be established to review and improve the effectiveness of antifraud programs and controls. These may include:
- Employees' annual declaration on 100% compliance with the "code of business conduct and anti-fraud policies"
- Adequate review/monitoring process to ensure that tip offs/complaints made through fraud hotlines are investigated/addressed appropriately
- Oversight by the audit committee of the risk of override of controls by management

Testing the adequacy of preparedness to handle fraud risk:

In order to test whether the organization is adequately equipped to handle fraud risks or to respond to situations when fraud is uncovered, the following points will be useful:

- Have we documented a formal fraud policy and a code of conduct and ethics policy?
- Have we adequately and appropriately communicated the code of conduct and ethics policy?
- Do we have an effective whistleblower mechanism in place to enable the reporting of instances of observed/ suspected instances of fraud?
- Have we trained our management team for the effective prevention and detection of fraud?
- Have we undertaken a fraud prevention health check to assess vulnerabilities to fraud?
- Does our risk assessment process specifically cover the risk of fraud?
- Is our internal audit team adequately equipped to cover the risk of fraud?
- Do we have an element of surprise in the internal audit process to deter fraud?
- Do we have adequate tools to detect suspicious or fraudulent transactions?
- Do we have the necessary skill sets to investigate fraudulent/ dishonest acts?

1.7 Fraud Detection

The *2006 Report to the Nation on Occupational Fraud and Abuse* indicates that around 34 percent of fraud cases were uncovered by advice being received (e.g., through the use of whistle-blower facilities), and a total of 51.4 percent were detected by the combination of internal audits, internal controls and external audits. There is little doubt that discovery of fraud by auditors relies heavily on evaluating and testing the operating effectiveness of adopted controls. But what percentage of fraud cases do IT auditors actually uncover? Currently, most of the IT audit programs appear to focus on compliance with established procedures and standards on operations of IT systems and applications, but with few internal control questionnaires (ICQs) aimed to detect potential fraud activities and to ascertain the effectiveness of antifraud control measurements in practice. Some possible explanations as to why this deficiency exists are that IT auditors:

- Tend to be too technically oriented
- Expect that uncovering fraud is the responsibility of financial auditors only
- Do not anticipate discovering any fraud activities when performing IT audits

Upon the completion of a fraud risk assessment with linkages to IT processes and associated detective controls, the IT auditor can build ICQs to evaluate and test adopted controls, including the antifraud programs. While financial auditors can evaluate the controls over a business's financial records and the appropriateness of its business operations, IT auditors should be focusing in areas around ICT systems and ICT-related processes. The quality of ICQs in detecting potential fraud may be strongly influenced by an IT auditor's competency in a technical sense, expert knowledge in specific areas (e.g., software programming, database administration, network design, network implementation, IT security), and insight to both IT and business operations. The development of these ICQs may reference established procedures within an organization, industry best practices and/or regulatory requirements.

For example, the complexity of technical and business arrangements in international long distance (IDD) call operations allows the fraudster to concede related activities from the company's financial record. Due to the "fixed" communication cost of the IDD provider, the fraudster could configure the IDD system to serve other IDD service providers without being detected by a financial auditor. In such a scenario, the fraud could be revealed by ICQs on system change controls, validation of system and/or application logs, or the logical security controls of the IDD system.

1.8 Fraud Investigation

The extensive use of ICT in today's business implies that evidence is extremely likely to be available for verification and confirmation as to an occurrence of a fraud. Evidence collected on ICT systems could well be used to sustain the occurrence of a fraud case. IT auditors tend to be better equipped with specialized knowledge on the behaviors of IT systems, and it is only a matter of whether an IT auditor is able to detect the fraud. To this extent, IT audits may either initiate or assist a fraud investigation through one or more of the following activities:

- Generation and/or reconciliation of report
- Identification/retrieval of evidence and missing records on computer system
- Conducting of computer forensics analysis

While an IT auditor may not be competent in conducting computer forensics analysis, the auditor should be aware of its methodology and capability.

1.9 Conclusion

IT auditors are expected to be involved in auditing for fraud both directly and indirectly. This article provides a fraud risk assessment approach covering various areas of fraud control through IT auditing, including:

- Integrating controls in the early stages of IT project development
- Raising necessary BICs and identifying EWSs as references for fraud prevention
- Developing ICQs around the process (both IT and business) instead of being technically focused
- Initiating and assisting in fraud investigations through the identification and recovery of direct and circumstantial evidence

The ability to identify and investigate a fraud by an IT auditor is strongly influenced by the extent of the IT auditor's knowledge of the business operations, IT process and technical know-how. Through this report, it is expected that IT auditors will have obtained a better understanding of the common practices that allow an enhanced level of fraud detection in an IT environment.

Summary

- **IP fraud:** An employee of a software development company sold the source code of the new software developed by the company to its competitors.
- **Data theft:** An employee of an organization sold a CD, suspected to contain confidential data pertaining to the customers of a bank.
- **Forex fraud:** An employee of a leading software company without proper authorization hedged the foreign exchange receivable by the company outside the normal course of the company's hedging process, which resulted in a loss of US\$30 million to the company.
- **Procurement fraud:** Employees of a technology company were sacked for allegedly showing preference to certain vendors/service providers and demanding favors from certain other vendors in lieu of the timely processing of their invoices/bills and the renewal of contracts.
- **Recruitment fraud:** The entire recruitment team of a large IT company was sacked for allegedly accepting bribes from prospective employees and recruitment consultants.
- **Payroll fraud:** An employee of a company drew salary even after six months of leaving the company.
- **Refund fraud:** Employees working in an organization misused their authority and created 30 dummy customer e-mail IDs and embezzled more than US\$1M, which was supposed to be paid as refund for dissatisfied customers.
- **Misappropriation of funds:** Few employees opened several dummy accounts to transfer the customer funds to these fictitious accounts.

Check your answers

1. What are the different types of IT frauds?
2. What is the role of IT Auditor in Fraud Control?
3. What is IT process?
4. How many processes are there in Cobit 5?
5. What are the impacts of frauds?

Lesson – 2

Introduction to Telecom Frauds

Learning Objectives

After reading this unit, you will be able to

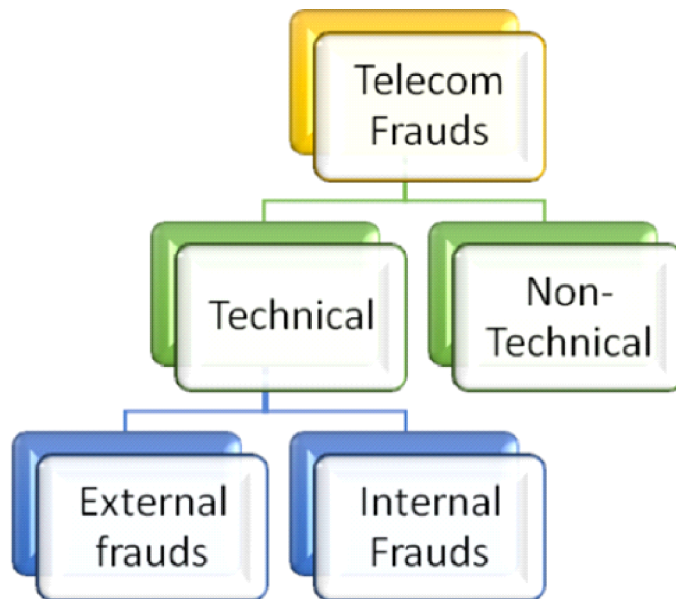
- Understand the telecommunication frauds to appreciate the preventive measures and legal position in India

Structure

- 2.1 Telecommunication Frauds**
- 2.2 Technical (External) Frauds**
- 2.3 Technical (Internal) Frauds**
- 2.4 Non-Technical Frauds**
- 2.5 The Growth Story**
- 2.6 How the Growth Story is hindered**
- 2.7 Fraudulent Subscriptions**
- 2.8 Preventive Measures**
- 2.9 Legal Position in India**
- 2.10 Conclusion**

2.1 Telecommunication Frauds

Telecommunication Frauds are classified into Technical and non-Technical frauds. Technical frauds are further classified into Technical external frauds and Technical internal Frauds.



2.2 Technical (External) Frauds

- Technical external frauds are committed externally, i.e. from outside the network, and are executed by gaining access into the network system using tools such as hacking.
- External frauds are usually impersonal, opportunistic and driven by pure greed.

Examples:

- Use of automatic telephone line isolators to penetrate into the secret code / password for dynamic STD lock / Personal Identification code (PIN).
- Accessing the O&M port of the switch from remote and perform opening & closing of telephones or other services.

2.3 Technical (Internal) Frauds

- Technical Internal Frauds are committed by gaining internal access to the network system.
- Internal frauds can be very different from external frauds and are more often than not be driven by personal grudges or revenge.

- Internal fraud reveals the breakdown of internal structures, the relationship between employer and employee, and the lack of internal controls to provide safety nets, checks and balances.

Examples:

- Manipulation of databases of billing, charging, routing, subscribers, etc.
- Changing the equipment number during preparation of bulk billing tape so that the metering information is transferred to the spare equipment number resulting in non billing.

2.4 Non-Technical Frauds

- Non-technical frauds are committed without accessing or interfering with the network system.

Examples:

- **Subscription Fraud:**

Subscriber registers for phone service, makes up a large phone bill mostly through call selling and absconds before disconnection.

- **Clip on fraud:**

The fraudster accesses the telecom infrastructure and diverts the line and makes calls or sells services to others.

- **Call Forwarding:**

The incoming calls coming to line are forwarded to a destination such that the calls are charged at much lesser rate which otherwise would have been charged as per the distance.

2.5 The Growth Story

- The Indian telecom sector has been one of the fastest growing in the world.
- Total telephone subscriber base reaching 601 million at the end of February 2010 from 582 million in January 2010, i.e. growth rate of 3.22%

2.6 How the Growth Story is hindered?

- Globally, fraud accounted for US \$150 billion in lost revenue for telecom operators in 2009
- As per CFCA Fraud survey, 2009, India is emerging as one of the top 5 hot spots for telecom fraud
- Fraud in telecom is second only to fraud in banking. It is growing exponentially and is expected to go up to 200 percent.
- The immediate concern and issues that telecom operators foresee due to fraudulent activity is loss of revenue, estimation of the loss of revenue is in the range of 1-5 % of total revenue.
- Developing markets face higher revenue leakage than developed markets due to rapid growth and the fast pace of technological changes.
- Telecom Frauds have a multifarious impact on telecom companies, effecting operations as well as the revenue streams.
- Some of the impacts of fraud for a telecom company are:
 - Direct financial loss through fraudulent call misuse (internal or external)
 - Missed cost savings opportunities through identification on un-needed circuits
 - Adverse publicity, damage to reputation and loss of customer confidence
 - Litigation and consequential financial loss
 - Loss of service and inability to dispense contractual obligations
 - Regulatory fines or increased regulatory supervision

2.7 Fraudulent Subscriptions

- One of largest reason for revenue loss of telecom companies is fraudulent subscriptions.
- The Department of Telecommunications has issued proper subscriber verification guidelines to the telecom companies.
- Revenue loss by reason of fraudulent subscription may be checked by following the governmental guidelines and implementing certain basic precautionary measures such as:

- ◆ Better screening and proper authentication of customers and ensuring procedural integrity of dealership network
- ◆ Telecom Enforcement, Resource and Monitoring Cells should be informed about the date of verification and uploading in relation to new connections.
- ◆ Documents submitted by the subscriber to the customer care executive should be verified with reference to the originals
- ◆ Restrictions on roaming and international calls, placing limits on outstanding invoices.

2.8 Preventive Measures

Internal Frauds:

- Internal fraud is a major threat and telecom companies need to take all essential steps to prevent and deter it.
- There are various ways of mitigating internal fraud, such as:
- Educate employees about policies and procedures, such as strict monitoring, penalization, whistle blower hotlines, etc
- Senior management should own the company's internal controls and keep a tight rein. Senior management's attitude is crucial for setting the tone from the top down
- Using automated systems to check misuse of critical functions
- Enabling deterrents by publicizing high profile fraud cases to deter would be fraudsters from committing fraud in future

2.9 Legal Position in India

- In India, telecommunication services are primarily regulated by the provisions of the Indian Telegraph Act, 1885 , the TRAI Act, 1997 and regulations issued by the Department of telecommunications.
- Section 25 of the Telegraph Act, 1885 deals with intentionally damaging or tampering with telegraphs and provides that if any person, intending –
 - a) to prevent or obstruct the transmission or delivery of any message, or
 - b) to intercept or to acquaint himself with the contents of any message, or

c) to commit mischief, damages, removes, tampers with or touches any battery, machinery, telegraph line, post or other thing whatever, being part of or used in or about any telegraph or in the working thereof, he shall be punished with imprisonment for a term which may extend to three years, or with fine or with both.

- Section 378 of IPC defines theft . However, section 378 of IPC defines theft as being of theft of moveable property Therefore definition of theft inadequate to cover majority of telecom frauds.
- Fraudulent subscription cases may be tackled under Section 419 of the IPC which deals with cheating by impersonation.

2.10 Conclusion

- Due to increase in process-oriented frauds and malicious frauds, it is important to implement an effective fraud management system
- People who commit frauds are more creative and innovative than the operator in terms of figuring out how to use these new services, so innovative measures need to be taken on a regular basis
- Experienced, well-trained staff, access to current fraud data, in addition to a powerful fraud management system are important tools in the fraud prevention arsenal
- By establishing a strong connection between marketing and fraud control, it is possible for carriers to offer new products and improve margins
- Telecom and other industry associations must lobby for a more stringent legal regime to be implemented with specific focus on telecom fraud
- Laws must permit companies to permanently blacklist employees found guilty of committing fraud as the same shall act as an important deterrent

Summary

- Technical external frauds are committed externally, i.e. from outside the network, and are executed by gaining access into the network system using tools such as hacking.
- Technical Internal Frauds are committed by gaining internal access to the network system. Internal frauds can be very different from external frauds and are more often than not be driven by personal grudges or revenge.

- In India, telecommunication services are primarily regulated by the provisions of the Indian Telegraph Act, 1885 , the TRAI Act, 1997 and regulations issued by the Department of telecommunications.
- Due to increase in process-oriented frauds and malicious frauds, it is important to implement an effective fraud management system.

Check your answers

1. What are technical telecom frauds?
2. What are non-technical telecom frauds
3. What are the preventive measures used to mitigate fraud?

Lesson – 3

Classification of Telecommunication Fraud

Learning Objectives

After reading this unit, you will be able to

- Understand the various types of telecom frauds with suitable examples

Structure

- 3.1 Introduction to Telecom Fraud**
- 3.2 Three Major Categories of Telecom Fraud**
- 3.3 Premium Rate Numbers**
- 3.4 Traffic Pumping Schemes**
- 3.5 Call Forwarding Fraud**
- 3.6 Multiple Transfer Fraud**
- 3.7 One Ring and Cut (Wangiri) Fraud**
- 3.8 Schemes to Defraud Telecom Service Providers**
- 3.9 Wholesale SIP Trunking Fraud**
- 3.10 Toll Free Fraud**
- 3.11 False Answer Supervision**
- 3.12 Location Routing Number Fraud**
- 3.13 Toll Bypass Fraud**
- 3.14 Inter/Intra State Tariff Bypass Fraud**
- 3.15 Schemes Conducted Over the Telephone**
- 3.16 Account Takeover**
- 3.17 Telecom Denial of Service (TDOS)**
- 3.18 Vishing**

3.1 Introduction to Telecom Fraud

According to the Federal Trade Commission, telecom fraud accounted for 34% of fraud complaints in 2012, up from 20% in 2010. These numbers continue to grow, as new technology has led to an onslaught of new telecom fraud tactics. The latest schemes are difficult to track and investigate because of their frequency, their layers of anonymity, and their global nature.

This guide will help you learn about the different types of telecom fraud and industry best practices for detection and prevention.

3.2 Three Major Categories of Telecom Fraud

We will divide the many telecom fraud schemes into three broad categories, based on who the fraudsters are targeting. These categories are:

- **Traffic Pumping Schemes** – These schemes use “access stimulation” techniques to boost traffic to a high cost destination, which then shares the revenue with the fraudster.
- **Schemes to Defraud Telecom Service Providers** - These schemes are the most complicated, and exploit telecom service providers using SIP trunking, regulatory loopholes, and more.
- **Schemes Conducted Over the Telephone** - Also known as “Phone Fraud,” this category covers all types of general fraud that are perpetrated over the telephone.

3.3 Premium Rate Numbers

Many of the call scenarios featured in this report make use of premium rate numbers. These premium rate numbers are usually to a high cost destination. The owner of the number will offer to share the revenue generated from calls to these numbers with anyone who sends them traffic. This means that a fraudster who generates bogus or stimulated traffic to that destination will receive a kickback for each completed call.

3.4 Traffic Pumping Schemes

The first major category of schemes of telecom fraud is called traffic pumping or access stimulation.

These are revenue sharing schemes, characterized by fraudsters whom greatly increase traffic to a specific high cost destination. The destination then shares a portion of their profits with the fraudster.

The call signature for these types of scenarios are spikes in traffic to high cost destinations.

Fraudsters often take advantage of lax security practices of a service provider's customers. A customer whose network has been compromised will often refuse to pay large fraudulent charges, leaving the service provider to cover the bill. Attacks frequently happen over holidays and weekends, when networks are often monitored less closely.

3.5 Call Forwarding Fraud

The Call Forwarding hack is a common form of VoIP telecom fraud. In this case, fraudsters gain access to an enterprise PBX or the IVR of a voice mail system. They can then configure call forwarding to an expensive long distance destination to profit from a revenue sharing deal. Typically the service provider's terms of service clearly state that the customer is liable for fraudulent calls generated from their phone system. In reality, however, few customers ever pay for fraudulent calls and the service provider bears the financial loss because their carrier forces them to pay for fraudulent calls.

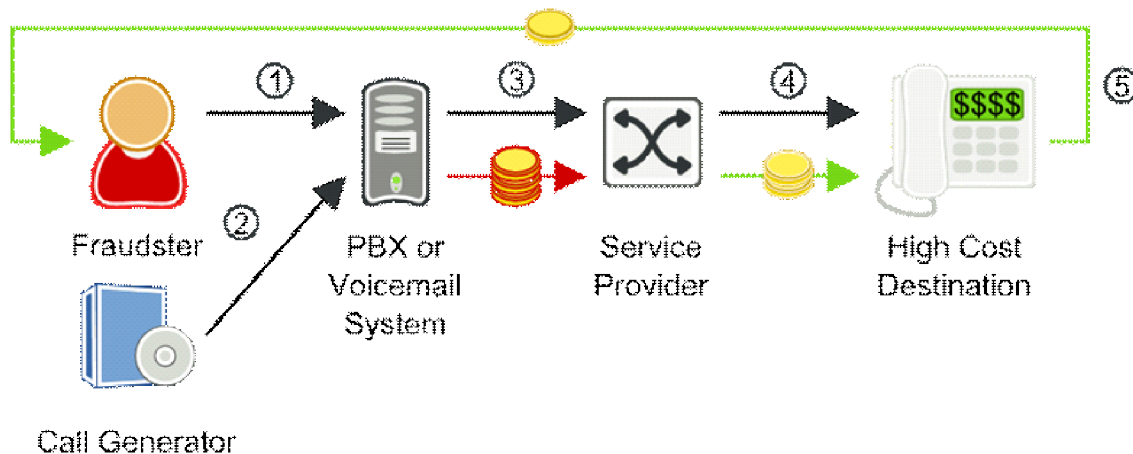


Figure 3.1 : Call Forwarding Fraud

Table 3.1 Call Flow Vs. Money Flow

Step	Call Flow	Money Flow
1	Fraudster accesses a PBX or the IVR of a voice mail system, compromises a user's login credentials, and sets the user's account to forward calls to a high cost destination	
2	Fraudster calls the compromised number over either PSTN or VoIP.	
3	The compromised PBX forwards the call to the service provider's soft switch.	The hacked enterprise technically owes the service provider payment for these calls, but will rarely pay.
4	The service provider switch routes the call to the high cost destination.	The service provider must pay its carrier for the fraudulent, high cost calls.
5		The fraudster has a revenue sharing deal with the high cost destination and receives payment.

3.6 Multiple Transfer Fraud

Multiple transfer fraud is an enhanced version of the previously described call forwarding fraud. In this fraud scenario, the call is transferred from the call source immediately after the destination answers the call. When the call is transferred, the fraudulent call is in progress with two high cost destinations and the call source hangs up. This fraud technique is especially harmful for several reasons.

- Each fraudulent call results in two call legs to high cost destinations.
- Since the call source is no longer in the call, it becomes more difficult to identify the source of the fraudulent calls.

- The hacked call source can repeat the process rapidly, one call at a time, to setup thousands of concurrent fraudulent calls through the service provider's softswitch. Most softswitches limit the maximum number of concurrent calls from a single customer. However, this call transfer fraud technique cannot be controlled by concurrent call limits since the call leg from the hacked phone source and the softswitch is very brief. A hacked customer phone with only a single call channel to a softswitch can generate thousands of concurrent fraudulent calls.

Call transfer is a sophisticated technique for multiplying the effects of telecom fraud, while making the fraud more difficult to detect. Once fraudulent calls are transferred, they stay up until the carrier shuts it down.

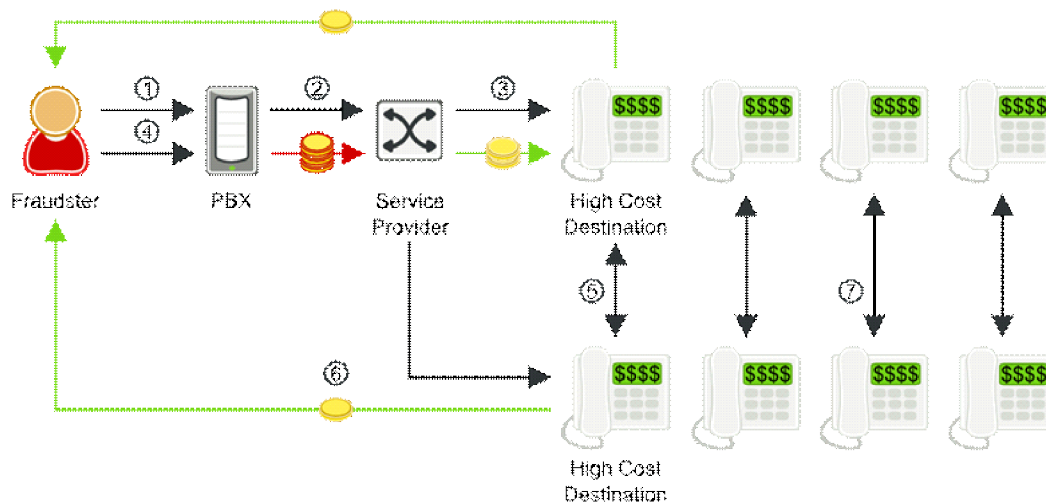


Figure 3.2 : Multiple Transfer Fraud

Table 3.2 Call Flow Vs. Money Flow

Step	Call Flow	Money Flow
1	Fraudster hacks an enterprise PBX to make calls to high cost destinations.	The hacked enterprise technically owes the service provider payment for these calls, but will rarely pay.
2	Compromised PBX sends SIP INVITE to service provider's soft switch.	

3	Service provider routes call to high cost destination.	The service provider must pay to complete the fraudulent, high cost calls.
4	Fraudster instructs PBX to transfer call to another high cost destination.	The hacked enterprise technically owes the service provider payment for these calls, but will rarely pay
5	The fraudster hangs up. The call between the two high cost destinations remains in place.	The service provider must now pay for two outbound calls to the high cost destinations.
6		The fraudster has a revenue sharing deal with the high cost destinations and receives payment.
7	Fraudster repeats steps 2-6 to set up hundreds or thousands of simultaneous calls.	

3.7 One Ring and Cut (Wangiri) Fraud

Wangiri, in Japanese, means “one and cut.” That is, one ring and a cut off phone call. A wangiri phone fraud scheme relies on this single ring method for a quick way to make money. A fraudster will set up a computer to dial a large number of phone numbers at random. Each rings just once, then hangs up. This leaves a number as a missed call on the recipients’ phone. Users often see the missed call and believe a legitimate call was cut off, or are simply curious as to who called, so they dial the missed number. This scam is often used to generate calls to Caribbean countries that have the same dial pattern as calls to USA numbers. The number turns out to be a premium rate number – anything from advertising to “free prizes” to sex services.

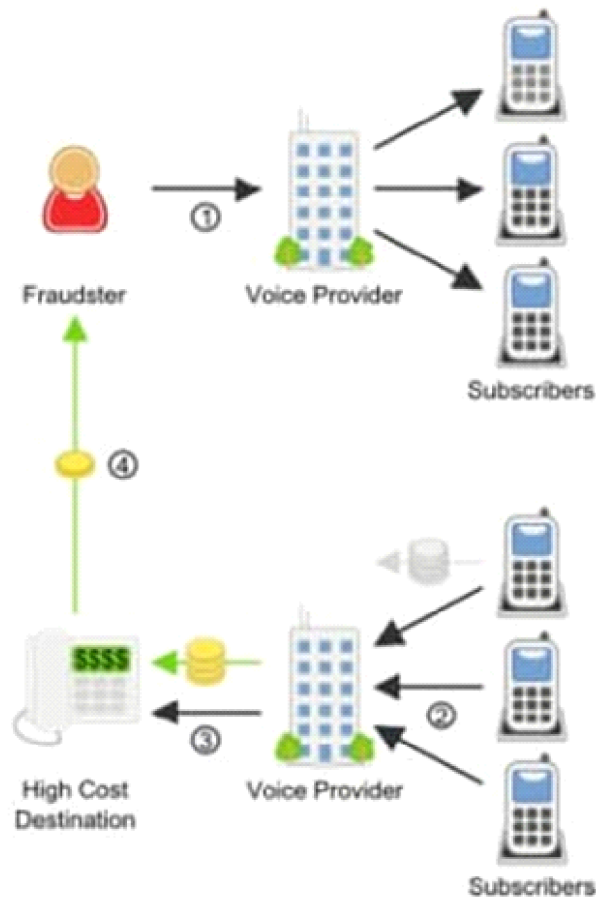


Figure 3.3 : Wangli Fraud

Table 3.3 Call Flow Vs. Money Flow

Step	Call Flow	Money Flow
1	The fraudster sets up calls to voice subscribers, but hangs up after one ring.	Because the calls are not answered, the fraudster isn't charged for making the calls
2	Curious subscribers see a missed call on their phones, and returned the call, not realizing that the number is actually a cost destination.	The subscribers technically owe the voice provider payment for these long distance calls, but will not be happy to pay, as the number looked like a domestic number.

3	Service provider routes call to high cost destination.	The service provider must pay to complete the fraudulent, the high cost calls.
4		The fraudster has a revenue sharing deal with the high cost destinations and receives payment.

3.8 Schemes to Defraud Telecom Service Providers

Telecom Service Providers are particularly vulnerable to telecom fraud. Fraudsters are able to manipulate telecom regulatory systems to their advantage, and to the disadvantage of the service provider, in ways that are difficult to detect, trace, and prosecute.

3.9 Wholesale SIP Trunking Fraud

Fraudulent wholesale trunking is a relatively new phenomenon, but one that is growing in popularity and difficult to detect. In this scenario, the fraudster is actually making money by selling wholesale trunking services, using stolen credentials to terminate the calls.

The key calling signature for this type of fraud is an increased number of apparently random calls. The destinations are not particularly high cost, but neither are they cheap. Countries like Vietnam, Laos, and other middle-priced Asian countries show up often. The traffic often appears to be to residential numbers.

Prepaid calling services are well suited to exploit this type of fraud since there are no calling numbers linked to customers. The IP address of the prepaid calling platform is the only link to trace the fraudster. Unfortunately, geolocation cannot always be used to identify the fraudster. These services can be offered via a tunnel through the Internet that hides the true IP address of the fraudster. The public IP address of the fraudster's calling platform could be the IP address of a hosted Virtual Private Network (VPN) service while the actual prepaid calling platform is located in a different part of the world.

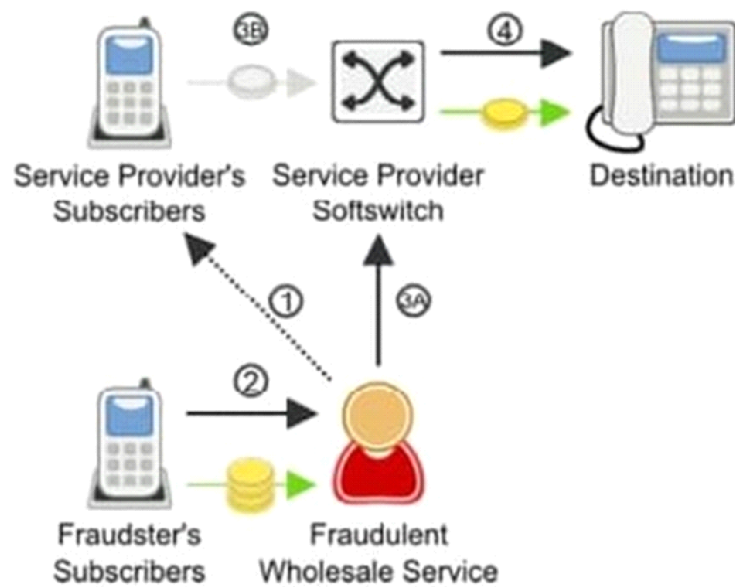


Figure 3.4 : SIP Trunking Fraud

Table 3.4 Call Flow Vs. Money Flow

Step	Call Flow	Money Flow
1	Fraudster steals credentials of the service provider's subscribers and registers with the service provider's soft switch using those stolen credentials.	
2	Fraudster's subscribers place a call	Fraudster's subscribers pay for service
3	Fraudster sends INVITE to service provider's soft switch.	Service provider's subscribers are billed for the call that was placed using their stolen credentials, but are unlikely to pay for the fraudulent calls.

4	Service provider router calls to their destination	Service provider must pay to complete the stolen call.
---	--	--

3.10 Toll Free Fraud

Toll Free fraud can affect any business that uses a toll free number. These calls are often left up for hours at a time and automated so multiple calls will be made at once. Fraudsters have gotten very sophisticated with this style of fraud, using different calling numbers for each call and only calling during business hours. They can navigate the IVR system to maintain a call for long periods of time, and vary the call duration so that the calls appear to be real traffic. When large companies, like financial institutions, are targeted, they frequently don't even notice the huge charges racked up by toll free fraud, even though they are expensive, long calls.



Figure 3.5 : Toll Free Fraud

Table 3.5 Call Flow Vs. Money Flow

Step	Call Flow	Money Flow
1	Fraudster makes calls to toll free customer.	The CLEC pays to the access the toll free database.
2	CLEC makes a dip to the toll free number.	
3	CLEC routes the call to the designated Toll Free provider.	
4	Toll Free Provider completes the call to the Toll Free customer.	Toll Free Customer pays the toll free provider the service fee.
5		
6		Toll Free provider pays the originating access fee to the CLEC
7		The CLEC shares part of the access revenue with the fraudster who created the bogus toll free traffic.

3.11 False Answer Supervision

When a dialled phone number is not in service, the calling party will hear a brief recording telling them so. There is no answer supervision or connection between the calling and called party. Since the call never connects, it is an incomplete call and should not be billed. However, fraudsters use false answer supervision to make these calls appear as completed calls which may be billed. Perhaps the fraudster has published rates for terminating calls without any intention of actually completing the calls. Here, service providers will route calls through the fraudster, who, instead of terminating the call, will play a not in service message and then bill the service provider for more than 10 seconds of calling. This type of fraud hurts the originating service provider both by costing money, and by hurting their reputation.

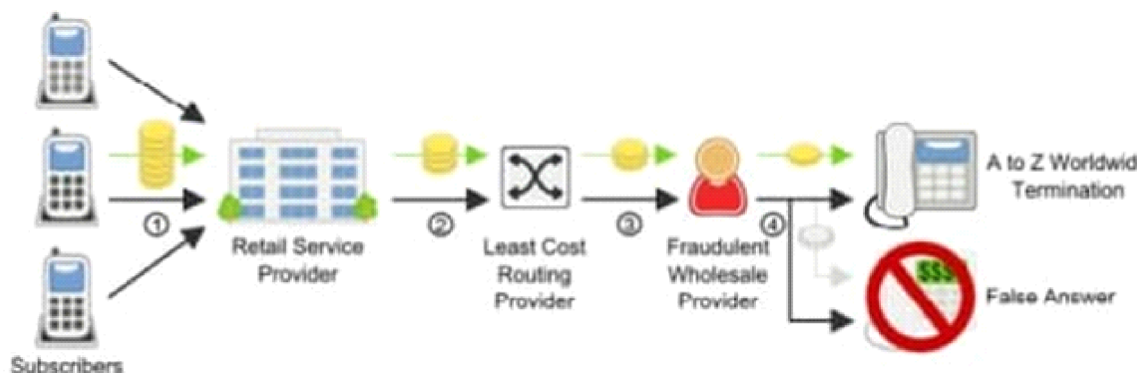


Figure 3.6 : False answer Supervision

Table 3.6 Call Flow Vs. Money Flow

Step	Call Flow	Money Flow
1	Subscriber makes a call	The subscriber pays their retail service provider for service.
2	Service provider routes calls to its wholesale Least Cost Routing Provider.	The retail service provider pays their LCR provider.
3	The LCR provider routes the call to a wholesale provider.	The LCR provider pays the wholesale provider for a completed call to the high cost destination.
4	In most cases, the wholesale provider completes the call, but in some cases, the wholesale provider router calls to the high cost destination with a “false answer” recording, not completing the call.	The wholesale provider pays nothing, because he did not actually complete the call to the high cost destination.

3.12 Location Routing Number Fraud

Location Routing Number Fraud or LRN fraud works based on the desire of some service providers to avoid extra charges from LRN “dips.” Most providers will run an LRN dip to determine the correct LRN for a dialed number. However, some service providers will not perform an LRN dip if the LRN is already in the SIP message. Fraudsters take advantage of this by inserting the LRN for a relatively cheap terminating destination in their SIP INVITES, when the call is actually going to a high cost rural destination. The service provider will route and bill the fraudster using the LRN included in the SIP

INVITE. The network that provides PSTN termination will route and bill for the call to the high cost rural destination using the correct LRN. The service provider will under-bill its customer for the call and will have to pay for the cost of the expensive rural call. In some cases, this can be up to 5x the price they billed the fraudster.

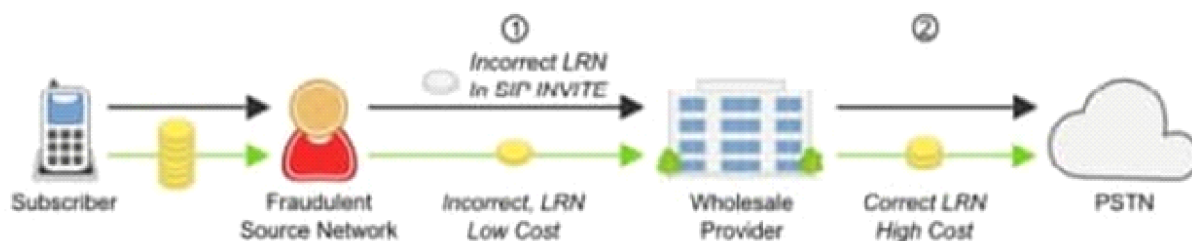


Figure 3.7 : Location Routing Fraud

Table 3.1 Call Flow Vs. Money Flow

Step	Call Flow	Money Flow
1	Source Network sends a call to a wholesale provider with an incorrect low cost LRN in the SIP INVITE.	Provider charges the Source Network for a call to the incorrect LRN.
2	The Provider completes the call.	The correct LRN for the call is more expensive than expected. The wholesale provider loses money, and the Source Network gets below cost termination.

3.13 Toll Bypass Fraud

Bypass fraud is the unauthorized insertion of traffic onto another carrier's network. In many countries, toll bypass for international call termination is criminal fraud. This scenario requires that the fraudsters obtain network access which makes international calls appear to be cheaper, domestic calls, effectively "bypassing" the normal payment system for international calling. One common technique for perpetrating this Interconnect fraud is GSM Gateway fraud, or SIM Boxing which is illustrated in the following diagram.

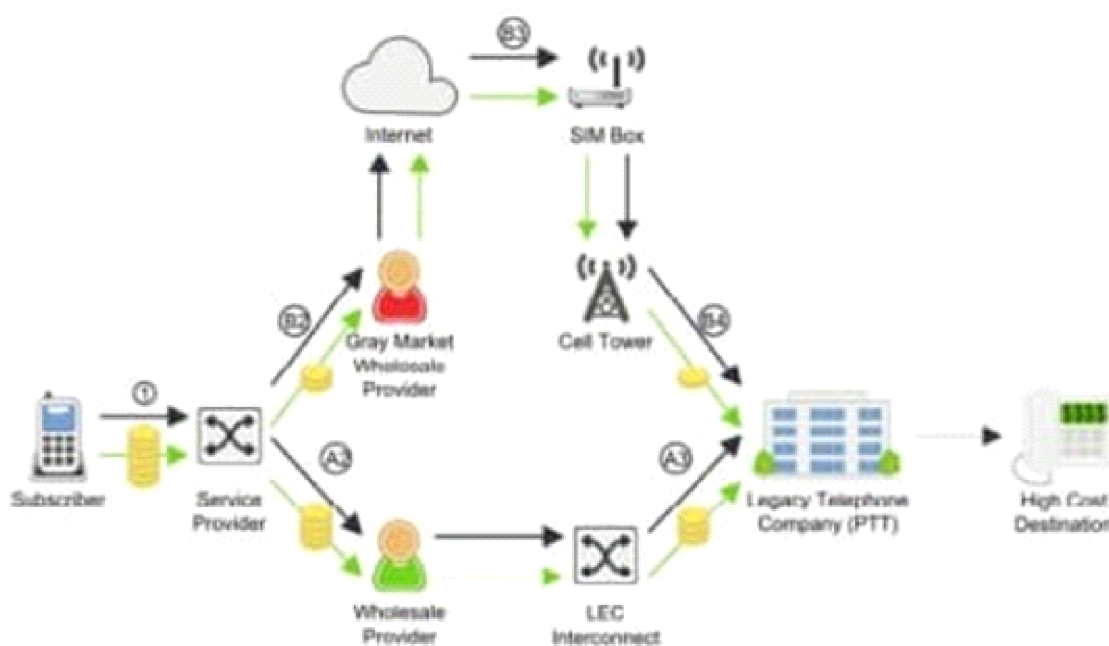


Figure 3.8 : Toll bypass Fraud

Table 3.8 Call Flow Vs. Money Flow

Step	Call Flow	Money Flow
1	Service provider has the choice to route a subscriber's call to a more expensive wholesale provider (A) or a lower cost "Gray Market" provider B	Subscriber pays service provider for service.

2	Service provider routes call to wholesale provider.	
3		Wholesale provider pays a toll to the International Legacy Telephone Company (PTT)
4	Service provider routes call to a lower cost gray market wholesale provider.	The service provider pays the gray market wholesale provider.
5	The Gray market wholesale provider routes the call through a SIM Box.	
6	The international call routed through the SIM Box to a cell tower looks like local subscriber traffic.	The gray market wholesale service provider pays a significantly reduced local traffic toll instead of the expensive international toll.

3.14 Inter/Intra State Tariff Bypass Fraud

Bypass fraud is the unauthorized insertion of traffic onto another carrier's network. Inter/Intra State toll bypass fraud attempts to bypass the higher tolls of intra-state traffic by making it look like inter-state traffic.



Figure 3.9 : Inter/Intra State Tarriff Bypass Fraud

Table 3.9 : Call Flow Vs. Money Flow

Step	Call Flow	Money Flow
1	Subscriber places an intra-state call.	Subscriber pays the service provider for service.
2	Fraudulent Service Provider changes the calling number of the call so that it appears to be a less expensive inter-state call	The fraudulent service provider pays the wholesale long distance provider for an inexpensive inter-state call.
3	Wholesale Long Distance Provider routes call to the LEC as an inter-state call.	The wholesale long distance provider pays the LEC for the inexpensive inter-state call.
4	LEC completes the more expensive intra-state call. But charges for a less expensive inter-state call.	The LEC must pay for the more expensive intra-state call and loses money.

3.15 Schemes Conducted Over the Telephone

Criminals of all sorts use telephony as a tool to defraud consumers and businesses. “Phone fraud” is a huge category, and can cover anything from Nigerian prince style scams to identity theft to extortion.

3.16 Account Takeover

With this type of telecom fraud, the fraudster generally attacks something like a financial institution.

Fraudsters will call financial institutions and maliciously impersonate another customer in order to steal the contents of an account. Pindrop Security estimates that a financial institution taking 50,000 calls per day will lose over \$10 million per year to phone fraud losses.

3.17 Telecom Denial of Service (TDOS)

Telecom Denial of Service (TDoS) attacks are similar to traditional data network denial of service (DDoS) attacks. In a DDoS attack, unauthorized users flood a system with too many access requests, preventing legitimate users from accessing the network. For TDoS, fraudsters make a huge number of phone calls, keeping them up for long durations, and overwhelming the capacity of an organization's phone network.

TDoS attacks can impair a voice network's availability, but can also be used as a tool for extortion. TDoS attacks have been in the news recently as a threat to public safety, as fraudsters have taken to using TDoS attacks against hospitals, police stations, and other public services.

3.18 Vishing

Phishing is a form of fraud that uses email messages with phony addresses, websites or pop-up windows to gather your personal information, which can then be used for identity theft. A form of phishing that uses the telephone instead of email is known as Vishing or "Voice-Phishing."

Vishers pose as a legitimate business to attempt to gather information from someone. That information can then be used for identity theft or other forms of fraud.

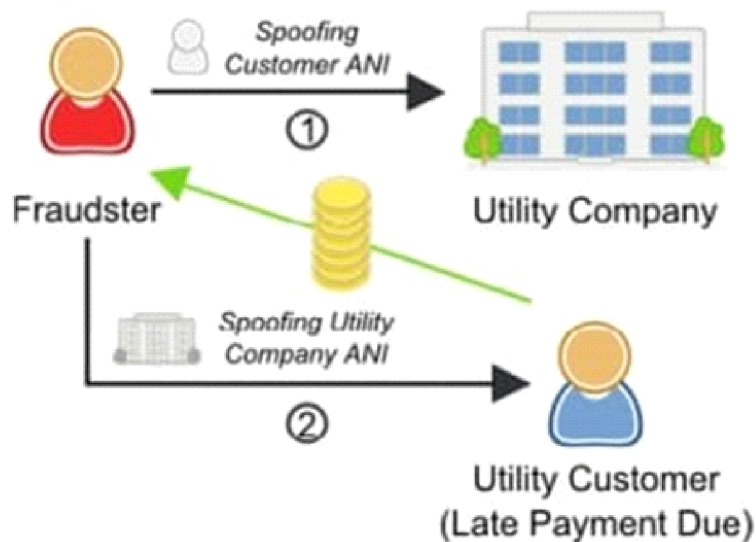


Figure 3.10 : Vishing Fraud

Table 3.10: Call Flow Vs. Money Flow

Step	Call Flow	Money Flow
1	Fraudster calls the Utility company while spoofing the ANI of a customer. The fraudster then navigates the utility's phone system to gather customer data, especially credit balance.	
2	Fraudster calls customer who are behind on their payments while spoofing the utility company's ANI. The fraudster pretends to work for the utility company, and demands payment over the phone in order to get the customer's credit card information.	The fraudster now has access to the utility customer's credit card information and can use it to make fraudulent withdrawals.

Summary

- **Traffic Pumping Schemes** – These schemes use “access stimulation” techniques to boost traffic to a high cost destination, which then shares the revenue with the fraudster.
- **Schemes to Defraud Telecom Service Providers** - These schemes are the most complicated, and exploit telecom service providers using SIP trunking, regulatory loopholes, and more.
- **Schemes Conducted Over the Telephone** - Also known as “Phone Fraud,” this category covers all types of general fraud that are perpetrated over the telephone.
- **Premium rate numbers** are usually to a high cost destination. The owner of the number will offer to share the revenue generated from calls to these numbers with anyone who sends them traffic. This means that a fraudster who generates bogus or stimulated traffic to that destination will receive a kickback for each completed call.

- The **Call Forwarding hack** is a common form of VoIP telecom fraud. In this case, fraudsters gain access to an enterprise PBX or the IVR of a voice mail system. They can then configure call forwarding to an expensive long distance destination to profit from a revenue sharing deal.
- **Wangiri**, in Japanese, means “one and cut.” That is, one ring and a cut off phone call. A wangiri phone fraud scheme relies on this single ring method for a quick way to make money. A fraudster will set up a computer to dial a large number of phone numbers at random. Each rings just once, then hangs up. This leaves a number as a missed call on the recipients’ phone.
- **Toll Free fraud** can affect any business that uses a toll free number. These calls are often left up for hours at a time and automated so multiple calls will be made at once.
- **Location Routing Number Fraud** or LRN fraud works based on the desire of some service providers to avoid extra charges from LRN “dips.” Most providers will run an LRN dip to determine the correct LRN for a dialed number. However, some service providers will not perform an LRN dip if the LRN is already in the SIP message. Fraudsters take advantage of this by inserting the LRN for a relatively cheap terminating destination in their SIP INVITES, when the call is actually going to a high cost rural destination. The service provider will route and bill the fraudster using the LRN included in the SIP
- **Internet Bypass fraud** is the unauthorized insertion of traffic onto another carrier’s network. Inter/Intra State toll bypass fraud attempts to bypass the higher tolls of intra-state traffic by making it look like inter-state traffic.
- **Telecom Denial of Service (TDoS)** attacks are similar to traditional data network denial of service (DDoS) attacks. In a DDoS attack, unauthorized users flood a system with too many access requests, preventing legitimate users from accessing the network. For TDoS, fraudsters make a huge number of phone calls, keeping them up for long durations, and overwhelming the capacity of an organization’s phone network.

Check your answers

1. Explain Traffic pumping schemes.
2. What is meant by Location Routing Number fraud?
3. Explain Toll Free Fraud?
4. What is Internet Bypass Fraud?
5. Explain TDoS.

Lesson – 4

Classification of Telecommunication Fraud

Learning Objectives

After reading this unit, you will be able to

- Study the classification of telecommunication counter measures to prevent them.

Structure

- 4.1 Call Selling**
- 4.2 Subscription fraud**
- 4.3 Insider fraud**
- 4.4 Calling cards**
- 4.5 Premium Rate fraud**
- 4.6 Hacking fraud**
- 4.7 Technical fraud**
- 4.8 Procedural fraud**
- 4.9 About PBX**
- 4.10 PBX HACKING**

4.1 Call Selling

Call selling is the practice of selling service to customers at below market rates but using another person's system and equipment to deliver that service.

The usual practice is to sell cheap international calls to an expat community. The community may well not be aware that the service they are using is illegal and is generally in support of cheaper calls back home.

The operator may have to make payments to his international partners as they will have connected a call. He will have a potential irate customer who will be experiencing bill shock and have the option of writing off all or part of the bill and the possibility of the customer churning. There is no relationship between the fraudster and the calls being made.

4.2 Subscription fraud

It involves the acquisition of telecommunications services using stolen or false credentials and/or identity with no intention of paying. With subscription fraud, not only do service providers lose revenue, but also individual consumers are vulnerable to having their identity stolen and credit rating tarnished.

4.3 Insider fraud

It occurs when individuals inside the operator provide fraudulent access to networks or otherwise thwart the ability of the operator to be paid for services used.

4.4 Calling cards

Calling cards themselves are usually just a way of remembering the card and account identity. There are many ways in which this information may be stolen including:

- *“Shoulder surfing”*, use of high-powered binoculars or cameras to watch the user entering the codes. Recording devices have also been used to eavesdrop on numbers spoken to the operator.
- *Simple theft* of the card itself.
- *Hacking*, where the fraudster uses repeated attempts to deduce or guess code combinations. Once the fraudster has the codes, the illicit use of them can often be carried out from a remote location to minimise the chances of being caught.

4.5 Premium Rate fraud

Subscription fraud can take many guises, but can be divided into two classes, one where people enter the contract with no desire to pay for service, and the other where people decide part way through a contract that they will no longer pay for service. The latter case usually results in a dramatic change in usage behaviour. However, the former case has no usage history to compare the initial heavy usage against. In this case additional subscriber information is required to try and assess the risk associated with the subscriber.

Premium Rate Fraud involves two actions - the setting up of a Premium Rate Service, and the acquiring of a number of phones to call this number. The actual mechanism used for perpetrating the fraud will depend upon the payment scheme used for the Premium Rate Service.

If the Premium Rate Service receives a share of the revenue generated for the Network, then the phones will make long duration calls to the Premium Rate number. If the Premium Rate Service receives money from the network according to the number of calls received by the Service, then the phones will make a high number of short duration calls. The phones that have been calling this number will then not have their bills paid. The signature of such fraud is therefore dependent on the payment scheme used for the Service, but will be a number of high risk phones either making repeated long duration calls or many short duration calls to certain Premium Rate numbers.

4.6 Hacking fraud

All frauds in this category generate revenue for the fraudster by breaking into insecure systems, and exploiting or selling on any available functionality. Examples of such fraud are PABX fraud and Network attack.

In PABX fraud, a fraudster repeatedly calls a PABX, trying to get access to an outside line. Once the fraudster has access to this, they can then dial out, making high value calls, whilst only paying for the low value PABX access call. Often, such attacks are associated with the use of cloned phones, so that even these low cost legs are not paid for.

In Network attacks, computer networks are attacked through the access modems that are used for remote management or support. Once a modem is hit, the fraudster then tries to break into the network and configure certain machines for his own end. Such frauds are characterised by rapid short calls to the same number in the case of PABX fraud, or short calls to sequential numbers in the case of Network fraud, and it is this behaviour that has to be detected.

4.7 Technical fraud

All frauds in this category involve attacks against weaknesses in the technology of the mobile system. Such frauds typically need some initial technical knowledge and ability, although once a weakness has been discovered this information is often quickly distributed in a form that non-technical people can use. Examples of such fraud are Cloning, Technical Internal fraud.

In cloning fraud, the phone's authentication parameters are copied onto another handset, so that the network believes that it is the original handset that is being authenticated.

In Technical Internal Fraud, fraudulent employees may alter certain internal information to allow certain users reduced cost access to services. The usage behaviour in these frauds depends on how long the fraud is expected to remain undetected. In the situation where the Fraudster believes that the fraud can be hidden for a long time, then the best approach would be to exhibit normal usage behaviour, as no attention is then drawn to it. However, if the fraud has a short lifetime, then the best approach is to make as much use of the service as possible until it is stopped.

4.8 Procedural fraud

All frauds in this category involve attacks against the procedures implemented to minimise exposure to fraud, and often attack the weaknesses in the business procedures used to grant access to the system. Examples of such fraud are Roaming fraud, Voucher ID duplication, and Faulty vouchers.

In the case of Roaming fraud, the billing procedure may mean that the Subscriber is billed a long time after the calls were made, in which case the subscriber may no longer be billable. Another aspect of this may be that the subscriber has been identified as a fraudulent roamer, but an error in the procedure of terminating his subscription means that he is able to continue making calls whilst roaming.

In the case of Voucher fraud, there may be problems associated with the procedures used to produce, distribute, activate and de-activate the PAYT vouchers. If the voucher information can be distributed to a number of people who attempt to activate the voucher at the same time, then if the procedure provides a time window between the phone account being credited and the voucher being de-activated, this may allow a number of people to use the same voucher. Such frauds usually display normal behaviour, and can only be countered by tightening up the procedures involved.

4.9 About PBX

PBX (Private Branch Exchange) systems started out as an internal company switchboards where operators manually directed calls from one person to the next. By the time the 80's rolled around, manual switchboards had been thrown aside, replaced with automatic switchboards that could route the call by itself. Fast forward to today, where PBX technology is taking on a whole new realm, the Internet world. Instead of routing calls through old switchboards and circuits, today's solutions use Internet protocol to exchange information.

This new world also enables users to work from virtually anywhere while still experiencing the full benefit of their networks PBX features. But, as we've stated previously, there's sometimes a cost associated with advancements in technology. For every worker able to telecommute from the beach, you can bet there's some hacker on that beach right next to him trying to see how they can gain access to that same network.

4.10 PBX HACKING

PBX hacking – the act of breaking into and accessing a company's PBX system and selling long distance/international telephone time to third parties – remains one of the leading types of fraud around the world. It's also nothing new, having first been reported in 2005. Since then, it has consistently been one of the main computer crimes reported to Fraud investigators all over the world.

Telephone hackers can take over insecure PBX systems to make international and long distance calls, listen to voice mail or monitor conversations.

The main economic reason fraudsters hack PBX systems is to gain access to the trunk lines after which they begin generating as many calls as possible to international premium rate numbers that they own off which the criminal collects 90% revenue.

Many businesses are unaware that they are responsible for all calls made from their phone system, including any fraudulent calls. More so, victims of hacked PBX systems are typically unaware of any unauthorized use and unwittingly allow the hackers to “sell” the use of their telephone system to others or, far worse give the hackers the opportunity to maliciously reprogram the system.

Summary

- **Call selling** is the practice of selling service to customers at below market rates but using another person's system and equipment to deliver that service. The usual practice is to sell cheap international calls to an expat community. The community may well not be aware that the service they are using is illegal and is generally in support of cheaper calls back home.
- **Calling cards** themselves are usually just a way of remembering the card and account identity. There are many ways in which this information may be stolen including:

- **Subscription fraud** can take many guises, but can be divided into two classes, one where people enter the contract with no desire to pay for service, and the other where people decide part way through a contract that they will no longer pay for service. The latter case usually results in a dramatic change in usage behaviour.
- In **PABX fraud**, a fraudster repeatedly calls a PABX, trying to get access to an outside line. Once the fraudster has access to this, they can then dial out, making high value calls, whilst only paying for the low value PABX access call. Often, such attacks are associated with the use of cloned phones, so that even these low cost legs are not paid for.
- **PBX hacking** – the act of breaking into and accessing a company's PBX system and selling long distance/international telephone time to third parties – remains one of the leading types of fraud around the world. It's also nothing new, having first been reported in 2005. Since then, it has consistently been one of the main computer crimes reported to Fraud investigators all over the world.

Check your answers

Explain the following:

- a. Calling Cards
- b. Subscription Fraud
- c. PABX Fraud
- d. PBX Hacking

Lesson – 5

Fixed Network Fraud

Learning Objectives

After reading this unit, you will be able to

- Know what is fixed network fraud types of SS7 security counter attacks and protection of mobile networks

Structure

- 5.1 The Development of Fixed Network**
- 5.2 Introduction to SS7 and Security**
- 5.3 SS7 Based Security Threats**
- 5.4 Spoofing**
- 5.5 Faking (MT Spoofing)**
- 5.6 Spamming**
- 5.7 Flooding**
- 5.8 Mobile Viruses**
- 5.9 Countering the attack**
- 5.10 Protecting mobile networks from SS7 attacks**

5.1 The Development of Fixed Network

Network operators around the world use a myriad of different network configurations to deliver broadband data connectivity (Table 1). However, there are in essence only two substances used for transport in fixed communications networks: copper and fibre-optic glass. Copper carrier systems are further subdivided into thin “twisted pair” cables originally designed for voice telephony and thick “coaxial” cables with greater capacity, primarily installed for cable television.

There are essentially five possible types based on the distribution of these three carriers in the distribution and “last-mile” segments of the network. The divisions are not exact, as many of them depend on how far out to the customer premises the network operator deploys fibre.

Table 5.1: The Development of Fixed Network

	Core	Distribution	Last mile
PSTN	Fibre	Twisted Pair	Twisted Pair
Cable TV	Fibre	coax	coax
Hybrid fibre coax	Fibre	Fibre	coax
Fibre to the node	Fibre	Fibre	Twisted Pair
Fibre to the home	Fibre	Fibre	Fibre

5.2 Introduction to SS7 and Security

Absence of security in SS7 is identified as a weakness, but not seen as a problem due to the following:

- Existing trust relationships amongst Telcos
- Closed networks
- Only experts are working and monitoring networks

Today networks are changing and protection for SS7 is becoming a necessity due to:

- The opening of the network for various (smaller) interconnect parties and service providers
- IP access to SS7 networks
- Less experts available to monitor networks
- More SMS service providers connecting to network, increasing the possibility of sending wrong messages without any purpose or trying to abuse the network.
- TCAP and protocols based on TCAP are more vulnerable to fraud.
- Don't need end to end physical connections
- Used in inter-PLMN communications Preventing SS7-Based Attacks using TCAP Security

5.3 SS7 Based Security Threats

5.4 Spoofing

Definition:

- Illegal use of HPLMN SMSC by a 3rd party.
- An MO SMS with a manipulated A-MSISDN (real or wrong) is coming into the HPLMN network from a foreign VLR (real or wrong SCCP Address).
- If the billing is made from the SMS-C data, the real subscriber will be invoiced.

Precaution:

- HPLMN can check the originator MSISDN (to verify if it's a real or not).
- HPLMN can check if the VLR location stored in the HLR is in the same range with the requesting SCCP address.

5.5 Faking (MT Spoofing)

Definition:

- A fake SMS is originated from the international SS7 network.
- SCCP/MAP addresses are manipulated.
- SCCP/MAP addresses are wrong or copied from a real existing SMSC.
- SMS can be sent to a real subscriber (recovering IMSI) or to a wrong IMSI (only to generate traffic).

Precaution:

- Controlling access to the SS7 network
- Supervision of foreign SMSC traffic

5.6 Spamming

Definition:

- Subscriber receives unwanted SMS.
- Sender can be valid.
- SMS can be billed correctly.

- SMS is submitted by a mobile phone or by a third party connected to the SMSC.
- Only real detection method is customer complaints.

Precaution:

- Repetitive content check
- SMS Firewall / SMS Router

5.7 Flooding

Definition:

- Massive load of messages to one or more destinations.
- The only parameter is the number of messages sent.
- May cause denial of service

Precaution:

- Supervision of traffic

5.8 Mobile Viruses

Definition:

- Unwanted signaling
- Stolen private information

Example:

- Hatihati

Precaution:

- SMS Defence

5.9 Countering the attack

There is no way to stop unauthorised SS7 Message Signal Units (MSU) from being injected into networks and so a solution must work by recognising and dealing with them before they can reach their intended destination.

One way this could be done is by placing a firewall at a network interconnect, for example a Signalling Transfer Point (STP) or International Gateway Exchange, and auditing MSUs as they pass through. Packets flowing through the firewall would be decoded and inspected where configured rules would be applied and traffic flow filtered accordingly.

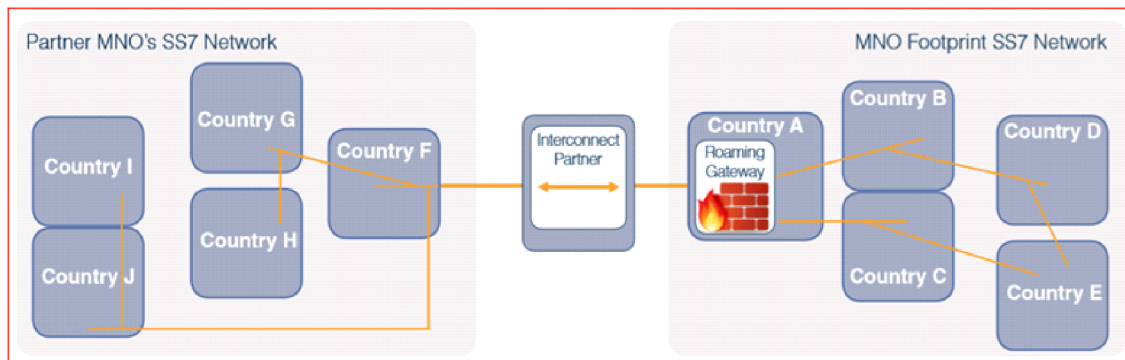


Figure 5.1 : Firewall located in Roaming gateway

Filtering rules could be applied at multiple levels of the SS7 stack to include the following parameters:

- Application Context
- Global Title
- PLMN ID
- Operation Code

Rules could be applied as blacklists, for MSUs to block, whitelists, which block all MSUs of a certain type except those specified and greylists, for events to log. By fully decoding MSUs at multiple levels the firewall could recognise spoofed messages, for example, by comparing the calling party digits in the Signalling Connection Control Part (SCCP) layer with those in the Mobile Application Part (MAP) layer. By blacklisting MSUs that contain mismatches between these two layers an operator could block spoofed messages on their network.

Returning to the example of the spammer compiling a list of phone numbers, a network operator may decide to use a whitelist to block all ATI requests except those originating from a list of trusted sources. When the attacker's ATI requests are received by the firewall they will be rejected when the source address is not found on the list. However, ATI requests from whitelisted sources will still be passed on.

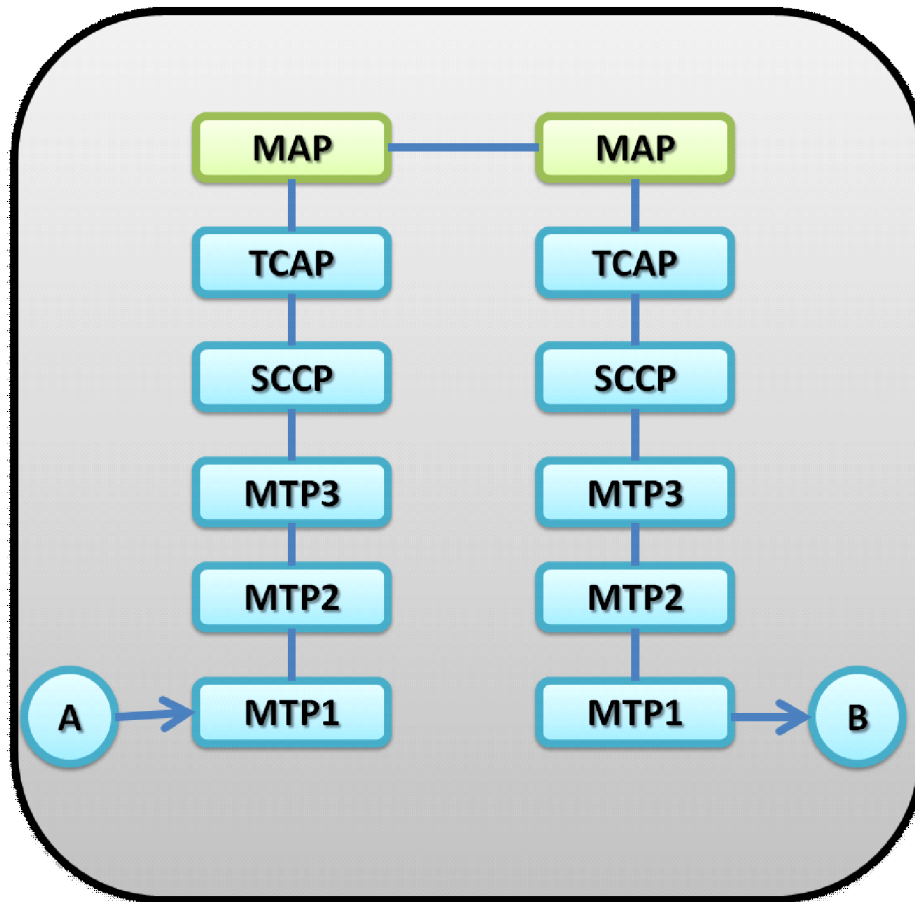


Figure 5.2 : Full decode of MSU for multi-layer filtering

5.10 Protecting mobile networks from SS7 attacks

Network operators' own data could also be utilised by the firewall to enable it to make more sophisticated judgements regarding MSU routing. If, for instance, the firewall had access to a subscriber's HLR 'velocity checks' could be performed to detect unauthorised MSUs. A location update from Australia for a subscriber who two minutes previously reported he was in France would clearly be illegitimate. A firewall with access to the relevant database could be programmed to recognise this and act accordingly.

To further improve the efficiency of the firewall data could be collected in order to build a picture of statistically normal network behaviour. A node that regularly receives large numbers of update Location requests, for example, is likely to be an HLR. If all of a sudden mt-forwardSM MSUs are detected as coming from this node it's likely they would be unauthorised as an HLR would not ordinarily send such a message.

Building a picture of normal network behaviour in this way could be used to detect International Revenue Share Fraud attacks (IRSF). IRSF attacks work by attaining a premium rate phone number or range of phone numbers from an international revenue share provider, who shares a percentage of the income generated from calls made to these numbers, and fraudulently initiating calls to them. Calls can be fraudulently initiated in a number of ways – SIM theft, international call forwarding, hacking Private Branch Exchanges (PBX) – but will often have a distinct signature when made for the purpose of IRSF. Known IRSF number ranges could be added to black or grey lists and suspicious activity, particularly long bulk calls to a single number, could be flagged as potentially fraudulent. By recognising suspicious activity like this as quickly as possible the firewall would enable the network operator to take action to block the fraudulent calls, saving money that would otherwise go to fraudsters.

Summary

- **SS7 Spoofing:** Today networks are changing and protection for SS7 is becoming a necessity due to: The opening of the network for various (smaller) interconnect parties and service providers. IP access to SS7 networks, less experts available to monitor networks
- SS7 based security threats include, spoofing, MT Spoofing, flooding, spamming, Mobile viruses.

Check your answers

1. Discuss SS7 Based Security Threats in detail
2. Explain the development of fixed networks.

Lesson – 6

Mobile Network Fraud

Learning Objectives

After reading this unit, you will be able to

- Learn the frauds in mobiles network and counter measures.

Structure

6.1 The Security of Mobile Network

6.2 Fraud in Wireless domain

6.1 The Security of Mobile Network

Mobile security is the protection of smartphones, tablets, laptops and other portable computing devices, and the networks they connect to, from threats and vulnerabilities associated with wireless computing. Mobile security is also known as wireless security.

6.2 Fraud in Wireless domain

Securing mobile devices has become increasingly important in recent years as the numbers of the devices in operation and the uses to which they are put have expanded dramatically. The problem is compounded within the enterprise as the ongoing trend toward IT consumerization is resulting in more and more employee-owned devices connecting to the corporate network.

In 2012 enterprise mobile security survey polled 487 IT security professionals and IT managers. The survey found the following top five mobile security concerns:

1. Device loss was the top concern. If an employee leaves a tablet or smartphone in a taxi cab or at a restaurant, for example, sensitive data, such as customer information or corporate intellectual property, can be put at risk. According to Marcus Carey, a security researcher at Boston-based compliance auditing firm Rapid7 Inc., such incidents have been behind many high-profile data breaches.
2. Application security was the second-ranking concern. One problem is mobile apps that request too many privileges, which allows them to access various data sources on the device. According to Domingo Guerra, president and co-founder of San

Francisco-based Appthority Inc., many mobile apps — especially free ones — are built with ties to advertising networks, which makes contacts, browsing history and geolocation data extremely valuable to application developers. As Guerra put it, “Developers want to monetize, consumers want free apps and then ad networks will pay developers to get all of that juicy data from their users.” According to survey respondents, leaked corporate contacts, calendar items and even the location of certain executives could put the company at a competitive disadvantage.

Another concern is malicious or Trojan-infected applications that are designed to look like they perform normally, but secretly upload sensitive data to a remote server.

3. Device data leakage was the third-ranking mobile security issue. Nearly all of the chief concerns identified in the mobile security survey, from data loss and theft to malicious applications and mobile malware, are sources of data leakage. While most corporate access privileges on mobile devices remain limited to calendar items and email, new mobile business applications can tap into a variety of sources, if the enterprise accepts the risks, said mobile security expert Lisa Phifer. Increased corporate data on devices increases the draw of cybercriminals who can target both the device and the back-end systems they tap into with mobile malware, Phifer said. “If you’re going to put sensitive business applications on those devices, then you would want to start taking that threat seriously.”
4. Malware attacks were the fourth-ranking mobile security concern. A new report from Finland-based antivirus vendor F-Secure Corp. found the vast majority of mobile malware to be SMS Trojans, designed to charge device owners premium text messages. Experts say Android devices face the biggest threat, but other platforms can attract financially motivated cybercriminals if they adopt Near Field Communications and other mobile payment technologies. An F-Secure analysis of more than 5,000 malicious Android files found that 81% of mobile malware can be classified as Trojans, followed by monitoring tools (10.1%) and malicious applications (5.1%).
5. Device theft was fifth on the list of top concerns. Smartphone theft is a common problem for owners of highly coveted smartphones such as the iPhone or high-end Android devices. The danger of corporate data, such as account credentials and access to email, falling into the hands of a tech-savvy thief, makes the issue a major threat to the IT security pros who took the survey.

Summary

- Securing mobile devices has become increasingly important in recent years as the numbers of the devices in operation and the uses to which they are put have expanded dramatically. The problem is compounded within the enterprise as the ongoing trend toward IT consumerization is resulting in more and more employee-owned devices connecting to the corporate network.
- Device data leakage was the third-ranking mobile security issue. Nearly all of the chief concerns identified in the mobile security survey, from data loss and theft to malicious applications and mobile malware, are sources of data leakage. While most corporate access privileges on mobile devices remain limited to calendar items and email, new mobile business applications can tap into a variety of sources.

Check your answers

1. Explain the Security of Mobile Network
2. Explain the Frauds in Wireless domain.

Lesson – 7

Common Telecommunication Frauds

Learning Objectives

After reading this unit, you will be able to

- Know common telecom frauds categories and prevention methods.

Structure

- 7.1 Clip on
- 7.2 Boxing Fraud
- 7.3 PBX Hacking
- 7.4 Unauthorized disclosure of Information
- 7.5 Unauthorized amendment of Data
- 7.6 Denial of Service (DoS) Attack
- 7.7 Toll fraud
- 7.8 Cloning
- 7.9 Cloning in GSM Networks
- 7.10 Tumbling or Magic Phone
- 7.11 Dealer or Reseller Fraud
- 7.12 Pre-Paid Cards
- 7.13 Social Engineering and Friendly Frauds
- 7.14 Insider Fraud
- 7.15 Identity Theft
- 7.16 Local Subscription Fraud
- 7.17 Roaming Subscription Fraud
- 7.18 Content and Value added frauds
- 7.19 Common Fraud Techniques usedToday

7.1 Clip on

Illegal parallel connection on the subscriber line and make someone else pay for the calls.

7.2 Boxing Fraud

Illegal stressing of national or international channel associated signaling systems.

7.3 PBX Hacking

A PABX/PBX (Private (Automatic) Branch eXchange) is telephone equipment that is installed on corporate premises to provide a number of telephone extensions within an office and operate as a connection between the business and the external dial-out network. A PBX allows sharing of outside lines and thus significantly reduces the number of such lines needed to be leased from a Telco. PBXs have evolved over time in much the same way that Telcos have evolved, moving from circuit switched to IP-based packet technologies. An on-site PBX provides more telecommunications service control to the organization. Today, even the most basic PBX systems have a wide range of capabilities that were previously only available in advanced large-scale switches. Today's voicemail platforms often have similar capabilities to PBXs, and thus are prone to similar attacks.

Typically, incidents tend to occur when business premises are unattended, PBX use is not monitored, and/or the PBX is accessible externally. Calls are placed and routed via the PBX and, in the majority of cases; the business owners are unaware of the event. In the most extreme cases, losses of thousands of Dollars can be incurred by businesses due to this type of fraud. We should understand that these "attacks" are possible because the victims are largely unaware of the potential threats and the PBXs in question have not been properly secured.

Popular methods of hacking PBXs are summarized in diagram below.

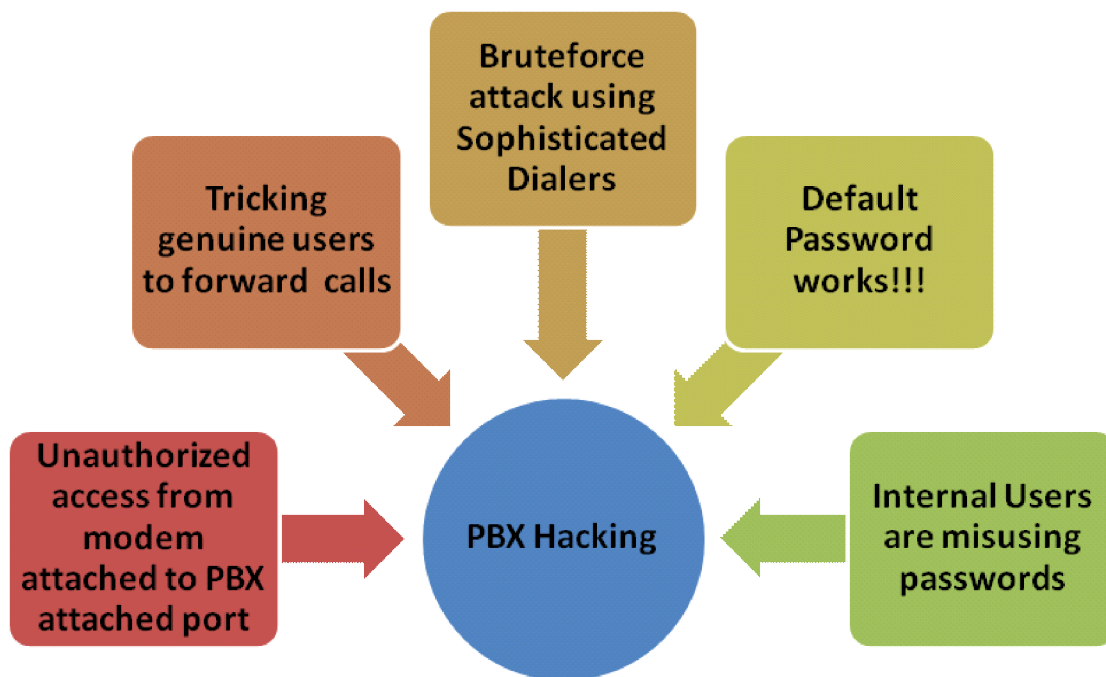


Figure 7.1 : PBX Hacking

7.3.1 Brute Force Attacks

Typically, the PBX security is breached via the toll-free Direct Inward System Access (DISA) number. Many PBXs allow dial-through, wherein a person calling into the PBX can access an external line by using appropriate passwords and control sequences. Large corporates use this feature extensively. Fraudsters hack into the PBX, obtain passwords and once a password is retrieved, use the PBX to generate outbound calls (typically for call selling or PRS revenue share).

“War dialing” is one of the techniques used for obtaining passwords. It involves the fraudster trying to break PBX code using an auto dialer, which keeps on dialing same number in a sequence making an exhaustive search of passwords until it breaks through.

7.3.2 Default Passwords

One of the largest contributing factors in PBX hacking and misuse is careless PBX installation and poor configuration, leaving default user and maintenance port passwords in

place (fraudsters know the default passwords for the various switch vendors). PBX fraud commonly occurs when the customer fails to change the default password or do not change passwords frequently. Default passwords can be found online in the relevant PBX user manuals etc. Telco and PBX vendors should advise corporate customers to changes all default settings and passwords. This will prevent easy hacking opportunities for fraudsters.

7.3.3 Internal Enemy

Many cases of PBX hacking result from insiders or vendors who disclose the phone numbers, IDs and passwords necessary for breaching PBX security. Sometimes the users may get hold of passwords by unauthorised means and use the corporate lines for making personal calls or colluding with external fraudsters to help in PBX hacking. Strict security Policies should be in force for PBX password control. The physical security of PBXs and phone extensions is also an important factor to consider in avoiding misuse of PBXs.

7.3.4 Social Engineering

The old traditional (wired) phone scam involving the 90# buttons on corporate telephone lines is still around. Employees of a corporation using a PBX line from their desk, receives a call from someone claiming to be a telephone company employee investigating technical problems with line, or checking up on calls supposedly placed to premium rate services or other countries from your line. The caller asks the employee to aid the investigation by either dialing 90# (or similar combination) or transferring him/her to an outside line before then hanging up the telephone receiver. By doing this the employee will be enabling the caller to place calls that are billed to the corporate telephone account. This attack only works on few PBXs today. Social engineering is another common technique used for obtaining passwords.

7.3.5 Service Port

PBX hackers may also target modems attached to the service PORT of a PBX. The facility is provided by PBX manufacturers to allow remote support of the PBX. Typically, the connection should be opened only when an authorized request goes from the PBX customer to the PBX vendor, but many PBX customers keep the connection always open and therefore prone to attack.

7.4 Unauthorized disclosure of Information

Loss, misuse, modification, or unauthorized access to sensitive information can adversely affect the privacy or welfare of an individual, trade secrets of a business or even the security and international relations of a nation depending on the level of sensitivity and nature of the information.

7.5 Unauthorized amendment of Data

The unauthorized changing of data before or during their input to a computer system. Examples are forging or counterfeiting documents and exchanging valid computer tapes or cards with prepared replacements.

7.6 Denial of Service (DoS) Attack

In computing, a denial-of-service (DoS) attack is an attempt to make a machine or network resource unavailable to its intended users, such as to temporarily or indefinitely interrupt or suspend services of a host connected to the Internet.

7.7 Toll fraud

Toll fraud is an expensive corporate crime that poses a major threat to telecommunications systems. Toll frauds can include the following costs:

- Expensive telephone charges
- Revenue loss because of its operational impact, additional expenses, and service interruptions
- Loss of customer confidence

7.7.1 Toll fraud overview

Toll fraud and long distance abuse are the unauthorized use of the company long-distance services. It occurs when people misdirect their own telecommunications charges to another person or business. An unauthorized party can be a person who is not a corporate employee, an agent, or a subcontractor.

7.7.2 Toll frauds

Toll fraud is possible when an incoming caller can make a network connection with another person. Once the outside line is obtained, hackers can make calls to anywhere in the world. Toll fees are charged to the owner of the private branch exchange (PBX). Protect vulnerable areas such as call transfer and bridging to an outbound call.

The following uses are only several in which unauthorized users can attempt to breach your system security:

- **Unauthorized system use.** Intruders use your system to create a mailbox and use the system. Hackers use personal computers, random number generators, and password cracking programs to break into customer premises equipment-based systems. Hackers continuously dial into the PBX or telephone equipment and probe the system for a weakness that provides access to an outside line. Once a hacker obtains an outside line, he or she can make long distance calls.
- **Unauthorized mailbox use.** An intruder discovers how to use a particular mailbox, perhaps by:
 - Finding the password on a subscriber desk or in a wallet
 - Trying all the common variations of passwords
 - Buying the password from a computer hacker who breached the system security and logged in as an administrator
- **Fraudulent call transfer.** An intruder uses the transfer-to-extension feature by transferring to the first few digits of a trunk access code.

7.7.3 Security Policy

- Security is a competitive parameter in the liberalized telecommunication world.
- Security protects the customers against incorrect bills and misuse from third parties.
- Security protects the company against accidental or by conscious caused losses or misuse of the telecommunication network.
- Security protects the employees against unjustified accuse on participation in criminal activities.

- Security is a part of the company image and a trade mark on all telecommunication products.
- Security is a demand from the community.

7.7.4 Managing the Risks

- Customer complains on product quality.
- Impenetrable or incorrect billing.
- Unauthorized physical access to the customers telephone line. (clip-on fraud)
- Unauthorized logical access to the customers telecommunication network and services.
- Unauthorized physical access to exchanges, infrastructure and buildings.
- Unauthorized logical access to network, exchanges and control systems.
- Unauthorized access to the administrative EDP systems and databases.

7.7 Cloning

Cloning is the best-known type of telephone fraud, afflicting analogue networks in particular. Cloning is the practice of programming the identity of a legitimate phone into another phone. The details of its identity are usually obtained either by eavesdropping on its interaction with the base station or by stealing it. Calls are then billed to the owner of the legitimate phone. Cases of multiple clones of the legitimate phone have been reported. This clearly multiplies the resultant financial exposure. At some point, the legitimate owner protests and is issued with a new identity, with the previous one being barred. To counter this, criminals have a variant on cloning called “tumbling”, whereby a phone is programmed with the identities of many other phones (99 in one case). Each time a call is made, the phone rotates between its identities, lessening the chance of detection and ensuring that the phone will work until all the accounts are barred. Cloned phones are often sold with a guarantee that they will work for a given number of months - if the clone is detected and the account is barred the supplier will replace it free of charge in the guarantee period. In the US, 75,000 phones are cloned each month and the problem is found wherever analogue mobile networks are present.

7.8 Cloning in GSM Networks

Phone's authentication parameters are copied into other handsets, so that the network believes that it is the original handset that is being authenticated. The telecom company charges the calls to original customer who will obviously deny having made such calls and consequently the telecom company will lose its revenue. It allows fraudsters to make high value calls for which the telecom company cannot collect any revenue. In addition, in most cases of cloning, the operator will have to make substantial payments to other telecom companies.

7.9 Tumbling or Magic Phone

Tumbling phones automatically seek an identity from a pre-programmed list, and Magic phones act as their own scanners copying identities from nearby phones in use.

7.10 Dealer or Reseller Fraud

Dealer fraud happens when a dealer / partner / third party supplies equipment or services with the intention of depriving the operator of revenue and increasing their own commission. This often includes false activation of accounts and the resale of devices, equipment or services outside the terms and conditions of the contract.

7.11 Theft

Despite an often-subsidised selling price, the handsets are valuable in themselves as well as in the network access, which they provide. They are thus an attractive target for theft. In the window of time before the theft is reported and the account barred, many high value calls can be placed, particularly using call-forwarding features to stack up multiple simultaneous calls. Alternatively, the phone may be cloned.

7.12 Pre-Paid Cards

Pre-paid subscription cards have been designed to allow a subscriber to pay for a certain value of calls in advance. This is an attractive proposition in that the subscriber has little opportunity

7.13 Social Engineering and Friendly Frauds

Social engineering, in the context of information security, refers to psychological manipulation of people into performing actions or divulging confidential information. A type of confidence trick for the purpose of information gathering, fraud, or system access, it differs from a traditional “con” in that it is often one of many steps in a more complex fraud scheme.

The term “social engineering” as an act of psychological manipulation is also associated with the social sciences, but its usage has caught on among computer and information security professionals.

Some of the techniques are Pretexting, Diversion theft, Phishing, phone phishing, Tailgating.

7.14 Insider Fraud

Insider fraud is perpetrated by a malicious insider, which is a current or former employee, contractor, or other business partner who has or had authorized access to an organization’s network, system, or data and intentionally exceeded or misused that access in a manner that negatively affected the confidentiality, integrity, or availability of the organization’s information or information systems.

7.15 Identity Theft

Identity theft is a form of stealing someone’s identity in which someone pretends to be someone else by assuming that person’s identity, usually as a method to gain access to resources or obtain credit and other benefits in that person’s name.

7.16 Local Subscription Fraud

Subscription fraud, which is defined as the use of telephone services with no intention of paying, is probably the most significant and prevalent worldwide telecom fraud (FML, 2003; Hoath, 1998). Subscription fraud can be subdivided into two categories:

- a) for profit, i.e. mainly for selling long distance calls and

b) for personal usage. Subscription fraud can be committed upon fixed and mobile telephones, and it is usually difficult to distinguish from bad debt, particularly if the fraud is for personal usage.

7.17 Roaming Subscription Fraud

To be truly useful, mobile phones should allow roaming between networks and across countries. However, fraudsters can exploit the time lag in sharing account activation and billing data between these operators. For example, a user can evade billing limits set by his home network by making high value calls whilst roaming across other networks. It is even possible to close the account in the home country, but still use the phone abroad for a certain period. Faster data transfer between operators - preferably by EDI - is the most effective solution to this problem.

7.18 Content and Value added frauds

Telecom Companies are providing Premium Rate Numbers (i.e. 52222, 59999, 57777 etc.) to their customers for value added services, wherein, all calls are charged at a very high rate. Content provider for Premium Number Service is entitled for revenue share on the basis of the number of incoming calls.

In such a scenario, a content provider may try to get the maximum number of calls using all tactics e.g. content provider may obtain another number with fraudulent documents / information with no intention to pay the bill and will make calls to Premium Rate Number for getting higher revenue.

7.19 Common Fraud Techniques used Today

7.19.1 Content Sell Fraud

The fraudster replicates and re-sells premium content, such as video or music files, at a fraction of the normal rate. This includes content resale (pirating) and IP infringement.

7.19.2 Content Artificial Inflation Fraud (AIT):

This is similar to traditional premium rate service (PRS) attack, but is increasingly associated with content downloads. It leaves the operator unable to collect fees from the fraudulent service use, but would be obliged to pay the content provider.

7.19.3 Click Fraud

In addition to content AIT, a specific type of internet-based fraud-commonly known as 'click fraud'. The fraudulent PRS content provider drives traffics to a paid content Website. This may be done manually, or by injecting phishing, malware to automatically use the service or hacking an operator's network to divert track to a content service, similar in nature to older auto-dialer attacks.

7.19.4 Crossover Fraud

Fraudster sends a "Trojan" to legitimate 3G subscribers. The Trojan causes the mobile devices of subscribers to automatically use service without the subscriber's authority or knowledge. This is commonly used to make premium rate calls that inflate revenues to the fraudster's own service.

7.19.5 IP Frauds

Networks adopting VoIP entice Hackers and criminals to capitalize on any weaknesses in the technology. VoIP is merely a transport protocol running on a data network which from a security viewpoint, is susceptible to all the attacks commonly targeted against data networks, even if they are not explicitly targeting voice over IP.

7.19.6 Malware

This general term applies to software that secretly installs viruses, key-loggers, etc - or malicious code executed on a computing device. It is another emerging fraud category that involves infecting devices with viruses and Trojans resulting in unauthorized actions. This might include making calls, deleting or stealing data. Once installed, unknown to the subscriber, a number of activities can take place, such as connections to PRS numbers, blocking calls, sending bulk SMS, or forcing legitimate services to fail.

7.19.7 VoIP Bypass

This fraud involves diverting legitimate fixed-line or mobile originating voice traffic into VoIP sessions. This results in a loss of revenue for the terminating operator.

7.19.8 IP Spoofing

Use of IP spoofing (substitution of identity information) is the most common method, often to aid other frauds by offering anonymity to the fraudster.

7.19.9 Spamming/Phishing

Spamming and phishing refer to messages (usually randomly) sent out, typically to trick customers into disclosing credit card numbers, account passwords or banking information, or to prompt them to call a PRS service. Such email / SMS/MMS messages often purport from spoofed mail address. Spam over Internet Telephony (SPIT) consists of unsolicited bulk messages that are broadcast to phones connected to the VoIP WLAN network. Fraudsters send voice messages (such as PRS call-back or marketing spam) in bulk. Methods include hacking into a computer used to route VoIP calls to target a large number of subscribers.

Selective Phishing – aimed at a specific group of individuals such as key workers within a company who may be dealing with customer details or financial data

Broadcast Attack – aimed at anyone randomly selected from a large group of individuals.

7.19.10 Money laundering

With the increase in m-commerce applications, micro-payments, and e-wallet/purse implementations, many new opportunities are opening up for money laundering. For example, use of phishing type emails to recruit persons to help with money transfers i.e. messages to recruit financial couriers in order to transfer their funds from one world location to another. Money laundering may also be conducted in a virtual IP environment, although recent controls are making this much more difficult e.g. “Second Life” where Linden Dollars could be exchanged for actual currency allowing movement money.

7.19.11 M-commerce related Frauds

Increasing opportunities and exploitation of m-commerce type services are opening the doors to Micro-payment frauds, including large-scale theft of (cheap) products, money laundering, and transaction denial. e.g. e-purse, wallet, or bank account (via banking application). M-Commerce could become more susceptible to fraud, due to tightening up of security and more attention to fraud threats being afforded in other Industry sectors (e.g. online retail).

Summary

- A PABX/PBX (Private (Automatic) Branch eXchange) is telephone equipment that is installed on corporate premises to provide a number of telephone extensions within an office and operate as a connection between the business and the external dial-out network.
- War dialing is one of the techniques used for obtaining passwords. It involves the fraudster trying to break PBX code using an auto dialer, which keeps on dialing same number in a sequence making an exhaustive search of passwords until it breaks through.
- PBX fraud commonly occurs when the customer fails to change the default password or do not change passwords frequently.
- Internal threats of PBX hacking result from insiders or vendors who disclose the phone numbers, IDs and passwords necessary for breaching PBX security. Sometimes the users may get hold of passwords by unauthorized means and use the corporate lines for making personal calls or colluding with external fraudsters to help in PBX hacking. Strict security Policies should be in force for PBX password control. The physical security of PBXs and phone extensions is also an important factor to consider in avoiding misuse of PBXs.
- Service Port - PBX hackers may also target modems attached to the service PORT of a PBX. The facility is provided by PBX manufacturers to allow remote support of the PBX. Typically, the connection should be opened only when an authorized request goes from the PBX customer to the PBX vendor, but many PBX customers keep the connection always open and therefore prone to attack.
- Toll fraud is an expensive corporate crime that poses a major threat to telecommunications systems.
- Cloning is the best-known type of telephone fraud, afflicting analogue networks in particular. Cloning is the practice of programming the identity of a legitimate phone into another phone. The details of its identity are usually obtained either by eavesdropping on its interaction with the base station or by stealing it. Calls are then billed to the owner of the legitimate phone. Cases of multiple clones of the legitimate phone have been reported.

- Pre-paid subscription cards have been designed to allow a subscriber to pay for a certain value of calls in advance. This is an attractive proposition in that the subscriber has little opportunity.
- Insider fraud is perpetrated by a malicious insider, which is a current or former employee, contractor, or other business partner who has or had authorized access to an organization's network, system, or data and intentionally exceeded or misused that access in a manner that negatively affected the confidentiality, integrity, or availability of the organization's information or information systems.

Check your answers

Explain the following:

1. war dialing
2. cloning
3. Insider Threat
4. PBX hacking
5. Prepaid Subscription

Lesson – 8

Frauds in 3G Networks

Learning Objectives

After reading this unit, you will be able to

- Know what is 3G network?
- Understand the frauds in 3G networks
- Security to prevent frauds in 3G networks

Structure

- 8.1 3G Technology Features, Advantages and Drawbacks**
- 8.2 Features of 3G:**
- 8.3 The 3G Business Model**
- 8.4 The 3G Hypermarket of Services**
- 8.5 Towards a Market Segment of One**
- 8.6 The Micro Payment**
- 8.7 Fraud Issues in 3G**
- 8.8 Subscription fraud**
 - 8.8.1 Credit card fraud on M-Commerce**
 - 8.8.2 Micro payment fraud**
 - 8.8.3 Premium Rate Service (PRS) fraud**
 - 8.8.4 Copyright infringement and content resale frauds ('piracy')**
- 8.9 Other Security & Law Enforcement Issues in 3G**
 - 8.9.1 Multi Media Messaging & Terrorism**
 - 8.9.2 3G Pre-paid Services and Money Laundering**
 - 8.9.3 Multi Media Messaging & Paedophilia**

8.1 3G Technology Features, Advantages and Drawbacks

Third-generation wireless technology is the advanced wireless technology. This technology enhances the features that were available in second generation and adds further advanced features. This technology is widely used in mobile phones and data cards.

8.2 Features of 3G

The ITU (International Telecommunication Union) has proposed 3G telecommunications standards to provide cost efficient high quality, wireless multimedia applications and enhanced wireless communications.

The features of 3G can be divided into two categories. One is data rates and the other is security.

- The main feature of 3G technology is that it supports greater voice and data capacity and high data transmission at low-cost. 3G mobiles can operate on 2G and 3G technologies.
- The second major feature is the security: 3G offers greater security features than 2G like Network Access Security, Network Domain Security, User Domain Security, Application Security.
- This technology provides localized services for accessing traffic and weather updates. Video calls and video conference is another major feature in 3G mobile technology. These features reduces the communication barriers between people, that were not sacked even with mobile phones.

Date transfer rates are high and can support even live TV channels over phone. Online media is another exciting feature in 3G mobiles. 3G mobiles highly attract the music lovers as they can listen to music and watch videos online and can download huge files with in less time.

New 3rdGeneration (3G) services “have been built to create a strong attraction, almost addictive or viral in nature” (Nokia White Paper). 3G is a short term for third-generation wireless, and refers to near-future developments in personal and business wireless technology, especially mobile communications. This phase is expected to reach maturity between the years 2003 and 2005.

The third generation, as its name suggests, follows the first generation (1G) and second generation (2G) in wireless communications. The 1G period which began in the late 1970s, featured the first true mobile phone systems, known at first as “cellular mobile radio telephone.” The 2G phase began in the 1990s, and much of this technology is still in use. The 2G phone features digital voice encoding, and examples include Code Division Multiple Access (CDMA), Time Division Multiple Access (TDMA), and Global Standard for Mobile (GSM) Communications. Since its inception, 2G technologies have steadily improved, with increased bandwidth, packet routing, and the introduction of multimedia. The present state of mobile wireless communications is often called 2.5G, the best example being the Global Packet Radio System (GPRS).

Ultimately, 3G, which is being delivered primarily on the Universal Mobile Telecommunications System (UMTS) platform, is expected to include capabilities and features such as:

- Enhanced multimedia (voice, data, video, and remote control)
- Usability on all popular modes (cellular telephone, e-mail, paging, fax, videoconferencing, and Web browsing)
- Broad bandwidth and high speed (upwards of 2 Mbps)
- Routing flexibility (repeater, satellite, LAN)
- Operation at approximately 2 GHz transmit and receive frequencies
- Roaming capability throughout Europe, Japan, and North America

The ultimate 3G system will be operational from any location on, or over, the earth’s surface, including use in homes, businesses, government offices, medical establishments, the military, personal and commercial land vehicles, private and commercial watercraft and marine craft, private and commercial aircraft (except where passenger use restrictions apply), portable (pedestrians, hikers, cyclists, campers), and space stations and spacecraft.

8.3 The 3G Business Model

As suggested, 3G operators will be forced to re-think the very meaning of ‘telecommunications’. In fact, pure communication will probably be a relatively small slice of what the new operator is about. The operator will be positioned to address service and infotainment opportunities related to virtually every aspect of the customer’s daily life, from food to travel, from sex to studies.

Operators are recognising this reality, and as a result there are three business concepts that are central to any discussion about the “3G future”, as explained below.



Figure 8.1 : 3G Hyper Market of Services

8.4 The 3G Hypermarket of Services

Simply put, the concept of a hypermarket of 3G services refers to the point made previously; that operators will be positioned to address all aspects of the customer's lifestyle. The expectation is that, like a supermarket, the 3G operator will divide its offering onto segments, each focusing on a different aspect of life. Within these segments there will be foundation services (e-mail, web browsing, etc.) 'seasonal specials' (e.g. cheaper picture messaging at Christmas) and 'one-off' services, such as ticket sales to next week's concert.

8.5 Towards a Market Segment of One

The second concept that operators are discussing is the theoretical market segment of one. This is the idea that, given enough data and enough computing power, it would one day be possible to address each individual customer as an individual human being with a unique lifestyle. So, for example, if Mark flies to London at 18:00 most Fridays, he could be offered information about airport traffic, the weather in London and films showing on Saturday and Sunday, all for a small fee. This information would be 'pushed' to Mark's phone, on the basis that if it is focused enough he will pay for it.

If advertising like this were to be pushed to a larger segment, a majority of recipients would probably be annoyed by the intrusion of such advertising on their handset, and extensive market segmentation and profiling is therefore seen as critical to the success of focused advertising, which in turn is positioned as a service within 3G, and expected to account for significant revenues.

8.6 The Micro Payment

Traditional M-Commerce (the mobile form of E-Commerce or Internet commerce) requires a customer to logon to the Internet from a terminal and select items to purchase. In most cases, the customer is then required to input a credit card number to complete the purchase. The transaction therefore involves several parties and types of revenue transaction:

- A telecom network operator who supplies an access line.
- An Internet Service Provider (ISP) who supplies access from the telephone network to the Internet, typically for a monthly fee.
- The content provider who sells the actual items that the customer wants to purchase.
- The credit card issuer who supplies credit to the consumer.
- A clearinghouse may also be required to authorise certain transactions.

This is a complex model, with every player trying to capture a share of the customer's wallet, making M-Commerce more expensive than was originally expected, as well as being exposed to fraud. Anyone who is familiar with the 'dotcom' collapse appreciates how difficult it is to get a customer to take out his or her credit card and order on-line.

If 3G operators simply offer handsets that act as mobile Internet terminals, it is unlikely that M-commerce will offer the operator the kind of revenue opportunity needed to recoup the investments made. However, consider the fact that a major focus of the operator will be the youth market, where small purchases are the norm, as well as the fact that recent statistics indicate that 20% of purchases globally are for items worth under \$14, and you have a major business opportunity for 3G operators, rather than a challenge, if the operator can develop an alternative business model.

3G operators have one distinct advantage in this scenario; the mobile terminal, with its SIM card, is both a device for browsing and a credit card. Purchases can be charged to the

customer's telephone account, and all the customer has to do to accept the transaction is to press the 'Yes' button. Authentication and authorisation are carried out using the same processes already in place for voice calls, and by focusing on small transactions, the operator can reduce exposure to fraud and compete with the credit card companies.

This is the concept of the '**micro payment**'; tiny payments (expected to be typically 5c to 10c each) carried out in huge volumes by the collective customer base, and charged directly to the customer's 3G account with no middleman to take out the profits.

8.7 Fraud Issues in 3G

Fraud can also be expected to evolve in 3G. Today, the motive of the typical fraudster is to generate traffic to expensive destinations, such as international numbers or premium rate service lines. Calls may be of long duration or high volume, but the value of the fraud is a direct function of the volume of traffic.

Under 3G, this will change. In the context of broadband services, billing will be based on a combination of data volume and quality of service (e.g. bandwidth priorities, etc.). Where micro payments are employed, fraud will involve many small transactions that will be very difficult to distinguish from normal purchases. This means that much of the reasoning behind today's fraud management systems and processes will become redundant in 3G, and new thinking about solutions will be required.

Some of the typical fraud issues in the early 3G networks are expected to be:

8.8 Subscription fraud

This involves applications for service with faked ID or stolen and other documents, to get by credit checks and allow the use of telephone services with no intention to pay the ultimate bill.

8.8.1 Credit card fraud on M-Commerce

Purchases of goods and services on the Internet or from sites hosted by operators themselves will continue under 3G, and the credit card will remain as one payment option. Credit card fraud (card theft, forgery and transaction repudiation fraud) is very widespread in existing services and this pattern can be expected to repeat itself in 3G services.

8.8.2 Micro payment fraud

Possibly using subscription fraud as the primary technique, fraudsters can be expected to purchase goods using micro-payments, charged to their 3G-phone account, and then default on payment, possibly having re-sold those goods for cash.

8.8.3 Premium Rate Service (PRS) fraud

This is already a problem today, with some operators of PRS lines (e.g. sex lines) organising fraudulent calls to their own numbers in order to inflate incoming traffic and up their revenues. Under 3G, PRS will take new forms, with streaming video and audio, as well as still images being downloaded and viewed for a fee. Clearly, the same type of fraud as that which occurs today will be possible on these new services.

8.8.4 Copyright infringement and content resale frauds ('piracy')

As music and video become mainstream products within the 3G portfolio, we can expect sophisticated attacks on this media designed to support illegal copying and resale, in the same fashion as VCR and DVD pirating is carried out today. This will be an obvious draw for organised crime.

8.9 Other Security & Law Enforcement Issues in 3G

Even at this early stage in the development of future services, it is apparent that the new capabilities that will be made available to the general public, with only minimal credit vetting and proof of identity requirements, offer significant opportunities for exploitation by the criminal element and by terrorists. Here are a few simple examples of possible scenarios:

8.9.1 Multi Media Messaging & Terrorism

A terrorist commander in a remote mountain hideaway in the Middle East requires a coordinated attack on several targets in the USA by separate operational cells. Information gleaned during the first attack will determine the exact target for subsequent attacks, but time is the critical factor as the follow-up attacks must be conducted before homeland defence forces can execute their contingency plans.

For security reasons, communication between each cell is prohibited, and it is also suspected that e-mail and voice communication to the commander may be monitored. However,

using 3G pre-paid mobile handsets, obtained with only minimal security checks (easily bypassed) and the multi-media messaging service, operatives can photograph their targets and mission results, add text and audio, and transmit the results to any compatible handset in the world in a few seconds.

Under 3G, secure, encrypted, high speed data communications will have been placed in the hands of every terrorist, current or potential, in the world.

8.9.2 3G Pre-paid Services and Money Laundering

A drug dealer has collected substantial sums of cash from his dealings and wishes to lodge this in various onshore bank accounts without raising suspicion. He uses his team to take out a number of pre-paid subscriptions, using faked identities. He then has his team members buy large denomination pre-paid top-ups in large volume, and he credits each account with several thousand dollars.

Using these heavily topped-up handsets, the dealer now purchases large quantities of merchandise in this simplified scenario. He then retails this merchandise from local stores, which he has rented or purchased, and lodges the proceeds in the bank, as legitimate takings from commerce.

3G in conjunction with the pre-paid service concept and loopholes in subscriber vetting and identification, places a sophisticated financial device capable of extensive cross-border utilisation in the hands of anonymous organised criminals, again on a global basis.

8.9.3 Multi Media Messaging & Paedophilia

A paedophile ring operating in the North East has been very restricted in its activities since interception of e-mail and investigation of web sites by law enforcement became widespread. With the new pre-paid picture messaging services, not only can they resume their communication in an anonymous and secure fashion, but they can transmit and view images in real-time from any location without being situated in a fixed location such as a garage or basement.

This sudden freedom does not only regenerate activity by previous offenders who had been operating under greater cover; it also brings a wave of new offenders into the area, who had previously been deterred by publicity about successful law enforcement operations. The service also allows commission of the offence in new locations and makes detection more

difficult; a teacher standing to one side could, for example, take and transmit images of children in a swimming lesson, using a cell phone sitting innocently on his belt.

Summary

- Third-generation wireless technology is the advanced wireless technology. This technology enhances the features that were available in second generation and adds further advanced features. This technology is widely used in mobile phones and data cards.
- Traditional M-Commerce (the mobile form of E-Commerce or Internet commerce) requires a customer to logon to the Internet from a terminal and select items to purchase. In most cases, the customer is then required to input a credit card number to complete the purchase.
- **Subscription Fraud:** involves applications for service with faked ID or stolen and other documents, to get by credit checks and allow the use of telephone services with no intention to pay the ultimate bill.
- **Micro payment fraud:** Possibly using subscription fraud as the primary technique, fraudsters can be expected to purchase goods using micro-payments, charged to their 3G-phone account, and then default on payment, possibly having re-sold those goods for cash.
- **Premium rate service fraud:** is already a problem today, with some operators of PRS lines (e.g. sex lines) organizing fraudulent calls to their own numbers in order to inflate incoming traffic and up their revenues. Under 3G, PRS will take new forms, with streaming video and audio, as well as still images being downloaded and viewed for a fee. Clearly, the same type of fraud as that which occurs today will be possible on these new services.
- **Copyright Fraud:** As music and video become mainstream products within the 3G portfolio, we can expect sophisticated attacks on this media designed to support illegal copying and resale, in the same fashion as VCR and DVD pirating is carried out today. This will be an obvious draw for organized crime.
- **Multimedia messaging and terrorism:** A terrorist commander in a remote mountain hideaway in the Middle East requires a coordinated attack on several targets in the USA by separate operational cells. Information gleaned during the first attack will

determine the exact target for subsequent attacks, but time is the critical factor as the follow-up attacks must be conducted before homeland defence forces can execute their contingency plans.

- **Paedophilia:** paedophile ring operating in the North East has been very restricted in its activities since interception of e-mail and investigation of web sites by law enforcement became widespread. With the new pre-paid picture messaging services, not only can they resume their communication in an anonymous and secure fashion, but they can transmit and view images in real-time from any location without being situated in a fixed location such as a garage or basement.

Check your answers

1. Explain in detail 3G technology.
2. Explain Credit card fraud in MCommerce.
3. Discuss in detail the following
 - a. Subscription fraud
 - b. Premium rate fraud
 - c. Terrorism and multimedia messaging

Lesson – 9

Fraud Management - A Strategic Perspective fraud management system

Learning Objectives

After reading this unit, you will be able to

- Understand the basics of fraud
- Management techniques and preventive actions.

Structure

- 9.1 Highlights**
- 9.2 Benefits**
 - 9.2.1 Flexible Double-layer Architecture**
 - 9.2.2 Thorough Protection Network**
 - 9.2.3 Intelligent Warning**
 - 9.2.4 Flexible Rule Setting**
 - 9.2.5 Thoughtful Analysis Functions**
 - 9.2.6 High Security**
 - 9.2.7 Functionality**
- 9.3 Fraud Detection**
- 9.4 Fraud Analysis**
- 9.5 Learnt**
- 9.6 Taught**
- 9.7 Management of Fraud Rule Base**
- 9.8 Preventive Actions**
- 9.9 Telco Protection through the FMS:**
- 9.10 Investigative**

9.11 Prosecution**9.12 Presenting the evidence in court****9.12.1 The Police and Criminal Evidence Act 1984 (PACE)****9.12.2 The Criminal Justice Act 1988 (CJA)****9.1 Highlights**

With the rapid development of telecom industry and enlarged user groups, various types of fraud have continuously emerged and caused great losses to telecom operators' revenues. By employing the data mining technology, FMS (Fraud Management System) analyzes existing frauds and obtains their features. By monitoring customers' consumption behavior, it promptly discovers and prevents any fraud happening again. By studying the existing consumption behavior of each customer, the FMS establishes a 'fingerprint base' for everyone and monitors his consumption behavior. This aims to find each customer's abnormal consumption behavior and prevents any new fraud happening.

9.2 Benefits**9.2.1 Flexible Double-layer Architecture**

The FMS employs double-layer architecture which enables fraud detection to separate from fraud rule base. It can promptly update the fraud rule base while monitoring operators' new products and services fast. This enables operators to be kept away from any loss caused by fraud while promoting customer satisfaction level.

9.2.2 Thorough Protection Network

The FMS can prevent existing fraud, such as purposive default, theft of telephone calls, voucher card fraud, and distributor fraud. Meantime, it promptly finds customers' abnormal behavior and prevents new fraud happening by comparing their consumption behavior with their fingerprint base.

9.2.3 Intelligent Warning

Upon finding any doubtful fraud, the FMS will immediately generate an alarm and guide alarm personnel to process it according to existing fraud cases and operators' solutions and suggestions. At the same time, it can automatically process this alarm as configured.

9.2.4 Flexible Rule Setting

By employing the data mining technology, the FMS can automatically generate various fraud-prevention rules. Besides, it provides a powerful manual setting function so that operators can integrate their own fraud-prevention experience into this system.

9.2.5 Thoughtful Analysis Functions

The FMS is capable of analyzing existing fraud so that operators can promptly find their service defects and block the source of fraud.

9.2.6 High Security

The FMS provides individual security management. It guarantees product security while preventing any fraud from users.

9.2.7 Functionality

9.3 Fraud Detection

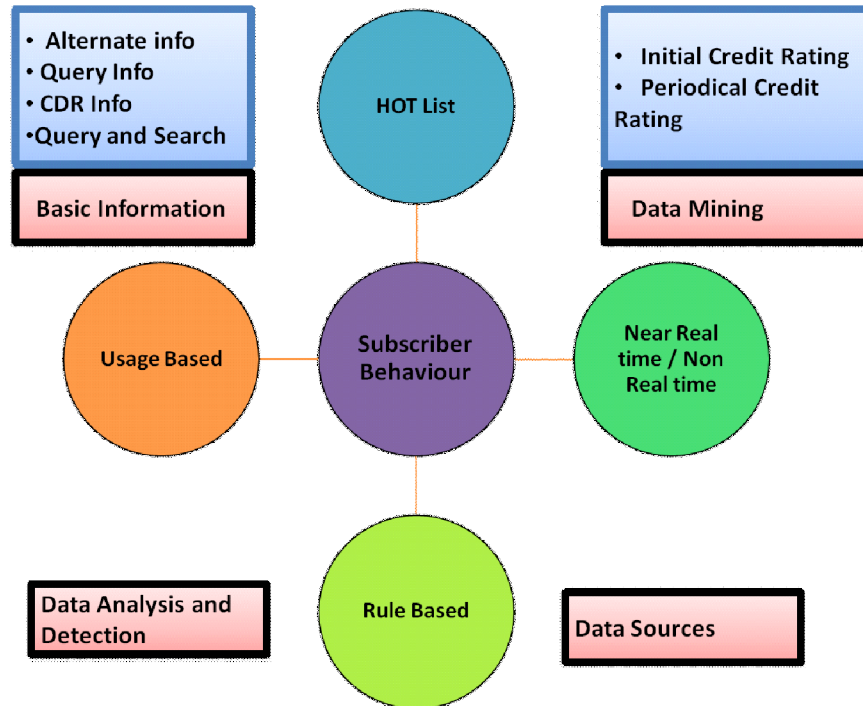


Figure 9.1 : Functionality of Fraud Management System

According to the customer fingerprint base and the fraud rule base, FMS monitors telecom services in different ways: real time or non-real time, so as to find out any fraud and suspected fraud. When finding such cases, the system will alarm and provide corresponding handling suggestions, for operators reference.

9.4 Fraud Analysis

The FMS product helps telecom operators not only stop any fraud but prevent it happening. Relying on the fraud analysis of the FMS product, operators can find the cause of any fraud and perfect their operating system.

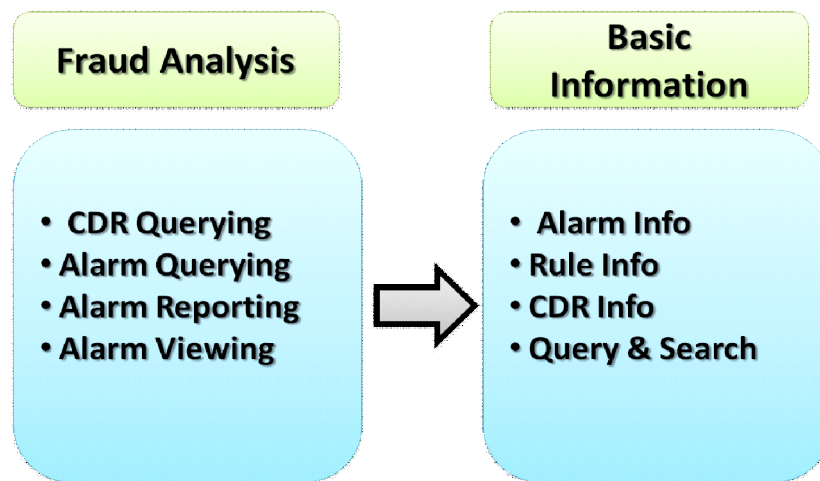


Figure 9.2 : Fraud Analysis

9.5 Learnt

In the learnt approach, a tool will learn what is typical behaviour, and raise an alarm on any large variations from this behaviour. In addition, the tool will generally evolve this typical behaviour over time as the Users behaviour changes. The tool's ability to monitor the behaviour of the User makes it very useful for detecting frauds about which nothing is known, as in nearly all cases of hacking or contractual fraud, these will result in changes of behaviour. If little is known about the fraud that exists in a system, this is a good tool to begin obtaining examples of fraudulent behaviour.

However, there are a number of drawbacks with such an approach. It is not possible to teach such a tool what to look for, and if the evolution parameters are not set correctly, clever fraudsters will learn how to 'ramp up' usage so as not to trigger an alarm.

An example of such a tool is the Unsupervised Neural Network. Here, the inputs to the tool are measured to determine a set of parameters that describe the behaviour of the User. The tool will typically maintain a measure of recent behaviour and longer term behaviour, and is then able to assess the current behaviour against both recent and long term behaviour profiles. These profiles will evolve in time according to some evolution parameters that will either be dependent on time or the number of calls.

9.6 Taught

In the taught approach, examples of fraud have been obtained. These are then used to 'teach' the tool what it is looking for. In the case of a Rule Based System, the fraud examples are analysed for their fraud signatures, and these are then translated into rules using thresholds or relative measures. In the case of a Supervised Neural Network, examples of fraud are used along with examples of non-fraudulent behaviour to teach the tool which behaviours are good and which are fraudulent. Both approaches should identify behaviours in some sense similar to the fraud examples used as fraudulent, and behaviours in some sense similar to good behaviour should be deemed non-fraudulent.

There are some differences between the Rule Based and Supervised Neural Network approach that should be noted. In the case of the Rule Based system, work has to be done at the beginning of the fraud process to identify the signatures and thereby the rules required to detect fraud. However, having done this work, the meaning of and reason for any alarm is immediately apparent. For example, if calls of duration greater than 1,000 hours is a good indicator of fraud, then an alarm raised by a Rule Based system will say that this alarm was raised because the call duration was greater than 1,000 hours.

In the case of the Supervised Neural Network, far less work has to be done at the beginning of the fraud process, as the tool simply needs to be taught against good and bad behaviour. However, any alarm that is raised will simply inform you that the Users behaviour is some measure of distance away from a fraudulent example. The analysis then has to be performed at the end of the process, by doing some further exploration of the behaviour. Although some

Supervised Neural Network tools simplify this process, it is still more labour intensive than a Rule Based approach.

However, both of these approaches have the drawback that new types of fraud are not being looked for, and may therefore remain undetected by the 'taught' tool whilst it may be detected by the 'learnt' tool.

9.7 Management of Fraud Rule Base

Management of fraud rule base is the core of an FM product. We analyze the service use behavior of existing customers and frauds by employing data mining technology. Now we have obtained the following rules:

- User fingerprint base
- Credit rating rules
- Fraud-prevention rules
- Fraud alarm handling rules

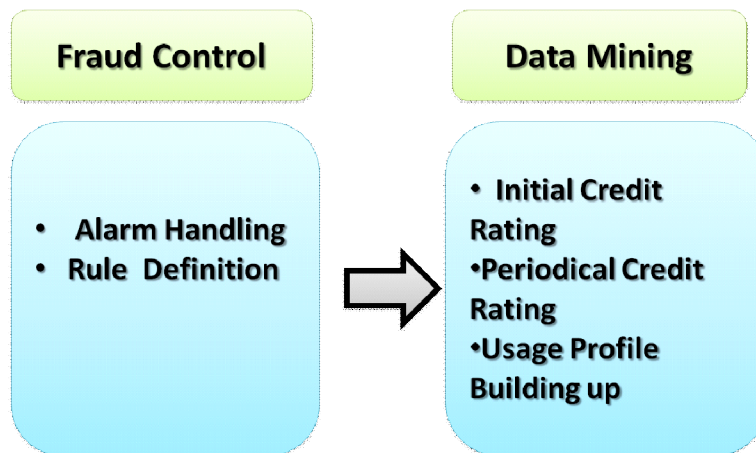


Figure 9.3 : Fraud Control

9.8 Preventive Actions

Telco Customer

- Should be informed of potential security threats to the PBX;
- Should maintain and enforce good security policies for the PBX;
- Should educate employees about threats (especially social engineering related) used for PBX hacking;
- Should ensure physical security of the PBX, phone lines and other equipment;
- Should Monitor international calls and high value services use through the PBX.

9.9 Telco Protection through the FMS

Simply by monitoring high usage for types of calls or traffic not expected for corporate customers. PRS calls, content download, and international calls to high-risk countries during unusual hours (e.g. night or weekend) can be good indicators that a company's PBX has been penetrated. Since many companies don't closely monitor their detailed phone bills on a line-by-line basis, this can otherwise go unnoticed for long periods of time.

FMS rules should be configured for off peak monitoring with appropriate filters and thresholds, high usage monitoring for PRS, content and International services, hotlist rules for high risk country codes and equipment identifiers. It is advised that xDRs (Usage record) processed in the FMS should have a field indicating whether a call originated or terminated at PBX. Once PBX hacking is detected, similar compromised lines can be identified based on behavioural profiles of blacklisted subscribers. Authorization failures from PBX (or Voicemail) authentication can be monitored using rules on log files. Profiling can be used to spot sudden changes in volume and/or the nature of use of PBXs. Again this is a strong indicator that a PBX has been hacked.

9.10 Investigative

The investigative approach is, as it suggests, a matter of auditing the procedures and technology that is employed. This can be performed either internally or by using an external company. Such an approach is extremely useful, and will become more important as exploiting procedural and technical frauds become more attractive.

One example of its usefulness is in ensuring that an employee cannot modify a database on your network so as to grant credit or free usage to certain subscribers. Another is that the machines on your network can not be accessed remotely in an unauthorised way. As cloning becomes more expensive, such approaches to obtaining fraudulent access to services will become more attractive.

9.11 Prosecution

Once a fraudster has been detected, and if it makes good business sense, the next step is to prosecute the fraudster. The principal piece of legislation used in the UK to prosecute cellular fraud is the

Telecommunications Act 1984 (the 1984 Act), as amended by the Telecommunications (Fraud) Act 1997 (the 1997 Act). Section 42 of the 1984 Act covers fraudulent use of a telecommunications system. It creates the specific offence of dishonestly obtaining a telecommunications service. The 1997 Act amends the 1984 Act by incorporating a new section (Sct. 42A) into the 1984 Act. Section 42A states that a person shall be guilty of an offence if he has in his custody or under his control “anything which may be used for the purpose of obtaining a telecommunications service” if he intends to use the thing to obtain such a service dishonestly or dishonestly allows the thing to be used to obtain a telecommunications service or for a purpose connected with the dishonest dealing of such a service. Section 42A has clearly been broadly drafted. The use of the term “anything” ensures that the legislation will not become redundant due to technological advances. In addition, the 1997 Act makes a person guilty of an offence where he supplies or offers to supply something to another, and he knows or believes that that person intends to use it dishonestly to obtain a telecommunications service or dishonestly to allow it to be used to obtain such a service or for a purpose connected with the dishonest obtaining of such a service. Fraudsters may be convicted summarily or on indictment under Section 42A. The former carries a maximum term of imprisonment of six months while the latter carries a maximum term of five years. In both cases, a fine may be imposed instead of, or, in addition to, a term of imprisonment. The 1997 Act is an example of fraud legislation which is sector specific. It applies to telecommunications services in general and therefore may be invoked against cellular fraudsters by both law enforcement authorities and private entities such as network operators and service providers.

9.12 Presenting the evidence in court

In the UK, electronic data e.g. call data is admissible as evidence in criminal proceedings under the provisions of the Police and Criminal Evidence Act 1984 and the Criminal Justice Act 1988.

9.12.1 The Police and Criminal Evidence Act 1984 (PACE)

Section 69 (1) of PACE provides that computer-generated documents may be admissible as evidence where there was no improper use of the computer and it was operating properly at all material times.

Even if the computer was not operating properly, this will not affect the admissibility of documents produced by it provided the malfunctioning did not affect the production of the document or the accuracy of its contents. Section 69 imposes a burden of proof on the party seeking to submit computer-generated documents in court. This burden is relatively easily discharged by the party providing the court with a certificate signed by the person occupying a responsible position in relation to the operation of the computer. The certificate identifies the document containing the statement and describes the manner in which it was produced. It also gives particulars of any device involved in the production of that document as may be appropriate for the purpose of showing that the document was produced by a computer.

Lastly, it deals with any of the matters mentioned in section 69 (1) e.g. confirming that there was no improper use of the computer or that the computer was operating properly at all material times.

9.12.2 The Criminal Justice Act 1988 (CJA)

Section 24 (1) of the CJA is subject to Section 69 of PACE and provides that a statement in a document shall be admissible in criminal proceedings if the document was created or received by a person in the course of a trade, business, profession or other occupation and the information contained in the document was supplied by a person (whether or not the maker of the statement) who had, or may reasonably be supposed to have had, personal knowledge of the matters dealt with. The term “document” is given a very broad meaning so as to include film, tape recordings and computer disks by virtue of Section 10 of the Civil Evidence Act 1968 (incorporated into the CJA by Schedule 2, paragraph 5).

Summary

- **Flexible Double-layer Architecture:** The FMS employs double-layer architecture which enables fraud detection to separate from fraud rule base. It can promptly update the fraud rule base while monitoring operators; new products and services fast. This enables operators to be kept away from any loss caused by fraud while promoting customer satisfaction level.
- **Flexible Rule Setting:** By employing the data mining technology, the FMS can automatically generate various fraud-prevention rules. Besides, it provides a powerful manual setting function so that operators can integrate their own fraud-prevention experience into this system.
- **Fraud Detection:** According to the customer fingerprint base and the fraud rule base, FMS monitors telecom services in different ways: real time or non-real time, so as to find out any fraud and suspected fraud. When finding such cases, the system will alarm and provide corresponding handling suggestions, for operators; reference.
- **Fraud Analysis:** The FMS product helps telecom operators not only stop any fraud but prevent it happening. Relying on the fraud analysis of the FMS product, operators can find the cause of any fraud and perfect their operating system.
- **The Criminal Justice Act 1988 (CJA):** Section 24 (1) of the CJA is subject to Section 69 of PACE and provides that a statement in a document shall be admissible in criminal proceedings if the document was created or received by a person in the course of a trade, business, profession or other occupation and the information contained in the document was supplied by a person (whether or not the maker of the statement) who had, or may reasonably be supposed to have had, personal knowledge of the matters dealt with. The term “document” is given a very broad meaning so as to include film, tape recordings and computer disks by virtue of Section 10 of the Civil Evidence Act 1968.

Check your answers

1. Flexible Double-layer Architecture
2. Flexible Rule Setting
3. Fraud Detection

LESSON - 10

FRAUDS IN 4G/LTE NETWORKS

Learning Objectives

After reading this unit, you will be able to

- Know what is 4G network
- Understand the frauds in 4G network
- Security to prevent frauds in 4G networks

Structure

- 10.1 4G Technology Features, Advantages and Drawbacks**
- 10.2 Features of 4G**
- 10.3 Applications of 4G**
- 10.4 Frauds in 4G**
- 10.5 How to deal with Frauds in 4G**

10.1 4G Technology Features, Advantages and Drawbacks

4G is the fourth generation of broadband cellular network technology, succeeding 3G. Unlike 3G or 2G, a 4G system does not support traditional circuit-switched telephony service, but it is based on all-Internet Protocol (IP) based communication such as IP telephony. It can support the data speed that are better than home broadband connection. This technology is getting deployed throughout most parts of the world. It can support HD Video calls, HD Video streaming & much more.

10.2 Features of 4G

The International Telecommunications Union ITU has specified IMT-A (IMT-Advanced) for 4G standards for high-throughput data services on mobile phones.

The following are some of the features of 4G.

- Support for interactive multimedia, voice, streaming video, Internet, and other broadband services

- IP based mobile system
- High speed, high capacity, and low cost per bit
- Global access, service portability, and scalable mobile services
- Seamless switching, and a variety of Quality of Service driven services
- Better scheduling and call admission control techniques
- Ad hoc and multi hop networks (the strict delay requirements of voice make multi hop network service a difficult problem)
- Better spectral efficiency
- Seamless network of multiple protocols and air interfaces (since 4G will be all JIP, look for 4G systems to be compatible with all common network technologies, including 802.11, WCDMA, Blue tooth, and Hyper LAN).
- An infrastructure to handle preexisting 3G systems along with other wireless technologies.

4G is all about convergence; convergence of wired and wireless networks, wireless technologies including GSM, wireless LAN, and Bluetooth as well as computers, consumer electronics, communication technology and several others.

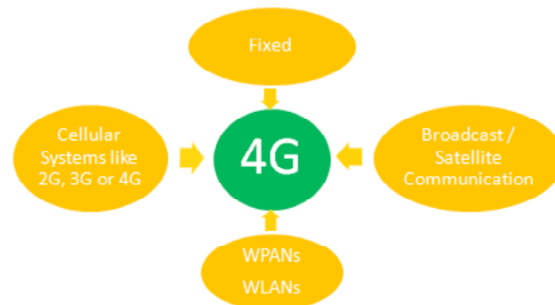


Figure 10.1 : 4G Convergence

10.3 Applications of 4G

Below are some of the applications possible with 4G Technology

- **Virtual Presence:** 4G system gives mobile users a “virtual presence” (for example, always-on connections to keep people on event). Video conferencing

- **Virtual Navigation:** a remote database contains the graphical representation of streets, buildings and physical characteristics of a large metropolis. These can be transmitted and help in navigation.
- **Location-based services** - a provider sends wide spread, real time weather or traffic conditions to the computer or phone or allows the subscriber to find and view nearby businesses or friends whilst communicating with them.
- **Tele-medicine** - a medical provider monitors or provides advice to the potentially isolated subscriber whilst also streaming to them related videos and guides. To provide improved health care services, advanced telecommunication technologies have been adopted widely for E-health services such as remote patient monitoring and trauma care of injured patients. 4G heterogeneous wireless access networks can be used to provide improved E-health service in both indoor(e.g hospital)and outdoor(e.g mobile ambulance) environments
- **HDTV** - a provider redirects a high definition TV channel directly to the subscriber where it can be watched.
- **Video games on demand** - a provider sends game data directly to the subscriber where they can play in real time.

10.4 Frauds in 4G

The transition to a broadband wireless service portfolio ushers in new vulnerabilities and threats to telecommunications and service provider organizations. As carriers deploy wireless Internet technologies to enable long term evolution (LTE) networks, attackers can use old Internet techniques to new effect through these broadband data services, targeting mobile devices and infrastructure.

Most carriers and service providers are fully occupied with the task of switching from circuit-switch, third-generation wireless (3G) technologies to fully Internet Protocol (IP)-enabled, fourth generation (4G), end-to-end technologies. They aren't fully aware of or focused on malicious actors.

Mobile threats to date have largely been reported in relation to "smart" devices and user data, not operator infrastructure.

Devices are simply the most obviously vulnerable aspect of the 4G network—the weakest link. LTE introduces new “weak links” throughout carrier infrastructure, as well as greater bandwidth and newly connected devices to exploit.

10.4.1 Malware attacks

Data-capable smartphones and tablets paired with large, wireless data pipes now attract significant attention from cybercriminal networks, today’s “organized crime.” From a negligible baseline, malware-based threats to mobile devices were up in high rate according to McAfee® Labs™. 1 Malicious software developers now readily take techniques developed for personal computers and adapt them to the limited footprint and technologies of mobile devices. For example, ZITMO stands for “Zeus in the Mobile,” a reuse of the widely adopted Zeus toolkit that makes malware programming easy for non-technical criminals. ZITMO perpetrates financial fraud by hijacking browsers and SMS authentication techniques.

10.4.2 Social engineering

Possibly more dangerous even than the spike in mobile malware is the spike in “SMiShing” and “phishing” attacks targeting the social relationships and curiosity of mobile users. These attacks involve malicious messages sent as emails or text messages to be consumed on the small screens and limited viewing areas of many mobile, smart devices. The message dupes a user into clicking a link, installing an app, or going to a website. The result is frequently that identity and credentials are handed over by the user to the attackers willingly but unknowingly; and serious fraud is the outcome.

10.4.3 Mobile to Mobile attacks

Unlike 3G traffic that tunnels directly into the core IP network from the mobile device, 4G traffic is all IP-based and can travel directly from mobile device to mobile device inside the wireless APN. This “peer to peer” (P2P) communication reduces backhaul traffic. However, it also permits mobile-to-mobile (Mob2Mob) attacks.

A compromised mobile device can target and scan large numbers of other, locally adjacent, mobile devices at once, consuming huge amounts of spectrum. This activity frequently goes unseen by the carrier because the wireless APN to which the device connects has limited instrumentation and few internal security capabilities. In addition to siphoning off spectrum, a mobile to mobile attack drains the battery on the victim’s device by maintaining a network

connection. The attack can also cause a denial-of-service (DoS) situation due to signaling congestion.

In an attack, the traffic may enter the network from one mobile device, perform an automated scan to look for devices with similar IP numbers (indicating that the devices are on the same subnet), and then reach back out over the 4G network to contact those devices. Once an attacker has exhausted one range of IP addresses, the attack moves to the next range and begins to attack and infect the new devices. Unfortunately, the mere act of scanning for responding IP addresses of other mobile devices can cause severe DoS due to the previously mentioned signaling congestion.

10.4.4 Machine to Machine Attacks

The Internet of Things (IoT) includes not only devices managed by people, such as desktops and smartphones, but semiautomated and fully automated devices that control physical outcomes, such as traffic lights, pipeline pressure sensors, electrical grids, and water utilities. These devices are sometimes referred to as engaging in “machine-to-machine” (M2M) networking. Traditionally, these fixed-function devices were built without much concern for security, since they used limited, dedicated networks that were not connected to a public network.

Simple probing of the network (performed by vulnerability scanners as well as would-be attackers) can have adverse effects by destabilizing controllers. Hindering potential mitigations, field-based sensors are resource-constrained, with minimal memory and CPU to spare: there is no “room” to install firewalls or even basic security capabilities.

In some cases, these devices run legacy, unpatched, and unpatchable operating systems. In most cases, even modern M2M systems and devices are not intended to operate within the hostile and unhygienic environment of the Internet—yet that is what 4G will become without adequate security.

When attacked, devices may just shut down—without warning, and sometimes without an easy or fast recovery. Disruption of ICS devices can lead to costly civil emergencies or loss of life. This feared scenario is driving critical infrastructure operators and the governments that regulate them to invest heavily in understanding and implementing more rigorous security controls. For service providers looking to provide the networks for these burgeoning new M2M applications, a degree of security and awareness related to mobile-on-mobile attacks will be a business enabler.

10.4.5 VoIP Attack

VOIP attack tactics that have evolved on the Internet can be used just as effectively against VOLTE. VOLTE infrastructure must be accessible from any mobile device subscribing to voice services from the service provider. In this age of pre-paid accounts and phones purchased and topped-up from automated kiosks, restricting only “friendly” and recognized subscribers to the VOLTE infrastructure is difficult.

There are several thousand known attacks against VOIP protocols that range in outcome from capturing administrative privileges to denial-of-service attacks. The impact on voice services to consumer and business users, as well as emergency services that support police, fire, and medical resources, can be highly disruptive and dangerous and result in regulatory issues. Because VOLTE traffic remains largely within the wireless APN, carriers need different monitoring equipment to detect attacks as they move through the 4G infrastructure to the VOLTE service infrastructure.

10.4.6 DNS Redirection Attack

This is perhaps the most dangerous attack. A DNS Redirection attack intercepts and modifies the destination IP address of a DNS request coming from the victim. The purpose of this attack is to re-direct the original DNS request to a malicious DNS server. With a DNS server under adversarial control, victims can be re-routed to harmful web sites that install malware or phishing sites that steal login information.

10.5 How to deal with Frauds in 4G?

Fraudsters are always trying new techniques to bypass service providers controls and gain free access to services. This not only deprives the operator of revenue, but also damages their reputation with subscribers and partners.

Fraud management teams must therefore be extremely agile to ensure they’re able to quickly and efficiently respond to a changing fraud landscape.

To cope with new types of fraud in VoLTE technology, it is vital that service provider implement faster techniques, such as machine learning. While there are limitations to machine learning, machines are much better than humans at dealing with, and processing, large datasets. They are able to detect and recognize thousands of features on a network event, instead of the

few that can be captured by manually creating rules. These systems must be capable of finding patterns of behavior that are different from the normal VoLTE subscriber, and be able to identify suspicious activities and/or fraud attempts, no matter how they are perpetrated, regardless of the scheme used, or the origin/termination point of the fraud.

To address these key capabilities, leading Fraud Management Systems (FMS) nowadays rely on algorithms. These can be designed and tuned to immediately identify the differences between fraudulent and legitimate events, to predict whether an event is likely be fraudulent before it is completed. As a result, a behavioral learning-based FMS is highly beneficial for service providers as it dramatically increases their knowledge of fraudsters' behavior, and quickly and efficiently generates potential fraud alerts.

10.6 5G Technology

5g technology has a huge demand and scope of offers to Indian market in view of scaling; it is all about growing capacity that is eventually predicted to be an outburst in the industry verticals that espouse 5G enabling a gamut of new services to encourage new business cases and usage models. The leading telecom operators already have new business case to be market ready in the 5G space. It is just India's swift readiness to embrace 5G not just from the operator stance but also from the regulatory viewpoint. Presently, India is not in the top 10 in market readiness for 5G. But, as against 2G, 3G & 4G, India is almost in sync with the global players from the deployment standpoint. Enabling the telecom operators of India towards Frequency Range 2 (FR2) or mmWave helps in deriving the true benefits of 5G upon the airwave allocation clearance by DoT and WPC (Wireless Planning and Coordination) wing.

On the contrary, 5g poses some critical challenges and concerns in the testing arena due to drastic changes in test methodology at the development and deployment stage with the use of technologies like mmWave. One of the major security challenges specific to India is that any security failure at a single data point could become ubiquitous throughout the network.

Summary

- **4G** is the fourth generation of broadband cellular network technology, succeeding 3G. Unlike 3G or 2G, a 4G system does not support traditional circuit-switched telephony service, but it is based on all-Internet Protocol (IP) based communication such as IP telephony. It can support the data speed that are better

than home broadband connection. This technology is getting deployed throughout most parts of the world. It can support HD Video calls, HD Video streaming & much more.

- **Applications of 4G**
 - o **Virtual Presence:** 4G system gives mobile users a “virtual presence” (for example, always-on connections to keep people on event). Video conferencing
 - o **Virtual Navigation:** a remote database contains the graphical representation of streets, buildings and physical characteristics of a large metropolis. These can be transmitted and help in navigation.
 - o **Location-based services** - a provider sends wide spread, real time weather or traffic conditions to the computer or phone or allows the subscriber to find and view nearby businesses or friends whilst communicating with them.
- **Frauds in 4G:** The transition to a broadband wireless service portfolio ushers in new vulnerabilities and threats to telecommunications and service provider organizations. As carriers deploy wireless Internet technologies to enable long term evolution (LTE) networks, attackers can use old Internet techniques to new effect through these broadband data services, targeting mobile devices and infrastructure.
- **Malware attacks:** Data-capable smartphones and tablets paired with large, wireless data pipes now attract significant attention from cybercriminal networks, today’s “organized crime.” From a negligible baseline, malware-based threats to mobile devices were up in high rate according to McAfee® Labs™.
- **Mobile to Mobile attacks:** Unlike 3G traffic that tunnels directly into the core IP network from the mobile device, 4G traffic is all IP-based and can travel directly from mobile device to mobile device inside the wireless APN. This “peer to peer” (P2P) communication reduces backhaul traffic. However, it also permits mobile-to-mobile (Mob2Mob) attacks.
- **DNS Redirection Attack:** This is perhaps the most dangerous attack. A DNS Redirection attack intercepts and modifies the destination IP address of a DNS request coming from the victim. The purpose of this attack is to re-direct the original DNS request to a malicious DNS server. With a DNS server under adversarial control, victims can be re-routed to harmful web sites that install malware or phishing sites that steal login information.

Check your answers

1. Applications of 4G
2. Frauds in 4G
3. DNS redirection attacks

References Acknowledged

- https://en.wikipedia.org/wiki/Phone_fraud
- [https://en.wikipedia.org/wiki/Cramming_\(fraud\)](https://en.wikipedia.org/wiki/Cramming_(fraud))
- <https://en.wikipedia.org/wiki/Phreaking>
- <https://en.wikipedia.org/wiki/3G>
- <https://www.utica.edu/academic/institutes/ecii/publications/articles/BA2A7651-0488-EE3E-C631D56228113857.pdf>
- <ftp://ftp.cordis.europa.eu/pub/ist/docs/ka4/10187.pdf>
- <https://www.itu.int/ITU-D/finance/work-cost-tariffs/events/tariff-seminars/djibouti-08/Peter%20Hoath-4-EN.PDF>
- <http://www.isaca.org/Journal/archives/2008/Volume-1/Documents/jpdf0801-practicing-information.pdf>
- <http://citeseerx.ist.psu.edu/viewdoc/download?doi=10.1.1.330.9231&rep=rep1&type=pdf>
- <https://www.neustar.biz/resources/whitepapers/csp/telecom-fraud-impacts-ebook.pdf>
- <http://www.cerebralbusiness.com/telecom/presentations/Tushar%20Chawla.pdf>
- <http://www.argyledata.com/files/Telecom-Fraud-101-eBook.pdf>
- <http://transnexus.com/wp-content/uploads/TFS.pdf>
- <http://dspace.mit.edu/handle/1721.1/34531>
- <http://www.slideshare.net/PO/telecom-signaling-attacks-on-3g-and-lte-networks>
- <https://books.google.co.in/books?id=ZvcuAqL418YC&pg=PA287&lpg=PA287&dq=frauds+in+3g+network&source=bl&ots=S-P93anM5p&sig=1bRXwAQHv3KRQ9dTbew2OGXAPLo&hl=en&sa=X&ved=0ahUKEwYpee9q-DJAhUFto4KHeL2A5EQ6AEIQTAG#v=onepage&q=frauds%20in%203g%20network&f=false>

MODEL QUESTION PAPER
M.SC CYBER FORENSICS AND INFORMATION SECURITY
FIRST YEAR - SECOND SEMESTER
CORE PAPER-VII
IT and Telecom Frauds & Countermeasures

Time:3 hours

Maximum : 80

Section-A

Answer the following in 50 words in each

**(10 x 2 =
20)**

1. What is Premium Rate Service Fraud?
2. What is PBX Hacking and how is it done?
3. What are mobile network security issues?
4. Cellphone Cloning fraud technique.
5. Explain subscription fraud?
6. How to mitigate wireless network domain risks?
7. What are the types of fraud which affects fixed line telecom?
8. Explain how intrusion detection system is helpful in finding intruders?
9. What are the risks involved in wireless domain?
10. What are mobile networks? What kind of frauds occur in wireless domain

Section-B

Answer any five of the following in 250 words in each

(5 x 6 = 30)

1. Explain how insider fraud can affect an organization.
2. What is signaling system 7 attack?

3. Explain the following:
 - a. Call transfer fraud
 - b. Wangri fraud
4. Explain the following:
 - a. Calling card fraud
 - b. Virus auto dialer fraud
5. What is Vishing? How are Vishing frauds done?
6. Explain TDOS attack in detail.

SECTION – C

Answer the following in about 500 words each (3 x 10 = 30)

1. What are technologies used in telecommunication?
2. Explain Fraud detection techniques.
3. What is telecom fraud? Discuss some telecom fraud cases.